Actividad práctica - Sesión 10

Seguridad backend: autenticación JWT y permisos

Kevin Eduardo Del Carpio Alegría · Ejecución: 15 de octubre de 2026

1. Objetivo y flujo de autenticación

Proteger PharmaBackend mediante cuentas de empleados, contraseñas BCrypt, tokens JWT y permisos agrupados en roles. La verificación comprende las 24 pruebas de seguridad de la guía: acceso público, credenciales, perfil, autorización, roles múltiples, alta de usuarios, integridad y expiración del token.

POST /api/v1/auth/login autentica las credenciales y devuelve un JWT Bearer, duración, nombre, roles y permisos. Cada petición protegida envía el token en Authorization. La cadena sin estado valida firma y expiración y carga la cuenta actual desde Oracle antes de autorizar el acceso.

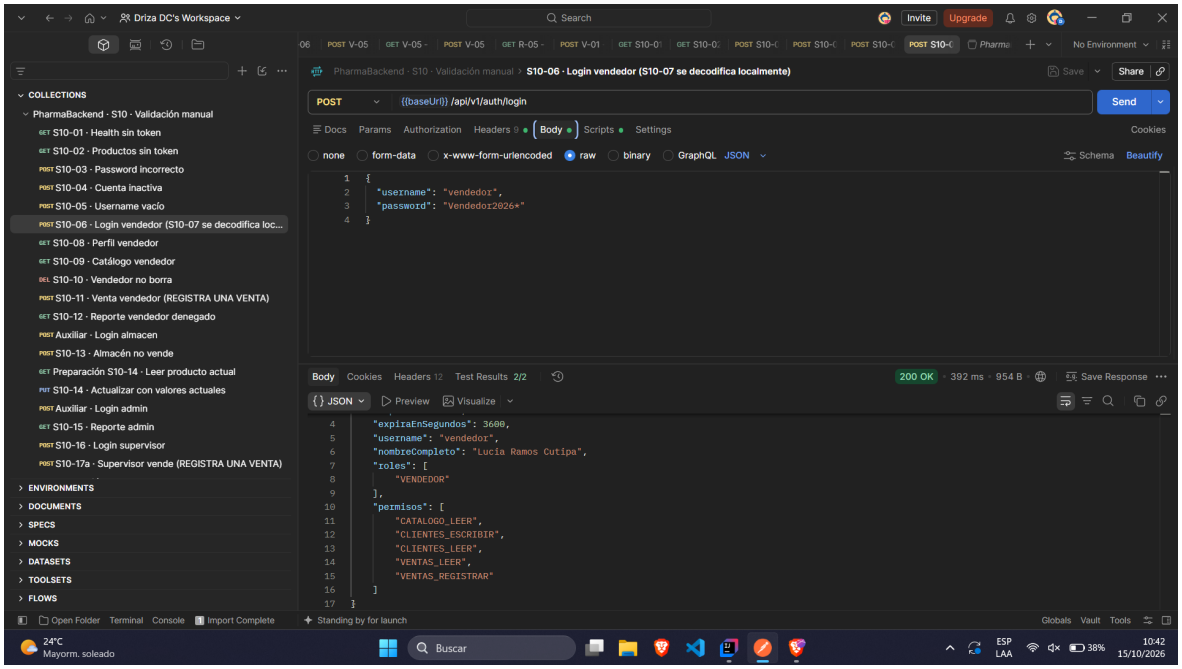


Figura 1. Login de vendedor: token Bearer, duración de 3600 segundos, rol y cinco permisos.

Un 401 indica ausencia de autenticación válida; un 403 identifica una cuenta autenticada sin el permiso requerido. Contraseña incorrecta y cuenta inactiva devuelven el mismo mensaje para evitar revelar la causa concreta del rechazo.

2. Modelo de seguridad y autorización

Empleado y Usuario mantienen una relación 1 a 1 mediante empleado_id único. Usuario y Rol se relacionan mediante usuario_roles. Las contraseñas se almacenan como hash BCrypt; los DTO de respuesta exponen datos planos y nunca incluyen contraseña ni hash. PermisosPorRol calcula la unión de permisos y añade ROLE_ para cada rol.

Operación	ADMIN	VENDEDOR	ALMACENERO	Ambos roles
Leer catálogo	Sí	Sí	Sí	Sí
Editar catálogo	Sí	No	Sí	Sí
Clientes y ventas	Sí	Sí	No	Sí
Reportes	Sí	No	No	No
Usuarios y roles	Sí	No	No	No

SecurityConfig aplica las reglas por URL y método. ReporteController exige REPORTES_VER con @PreAuthorize. El supervisor combina VENDEDOR y ALMACENERO: puede vender y actualizar productos, pero esa unión no incluye acceso a reportes.

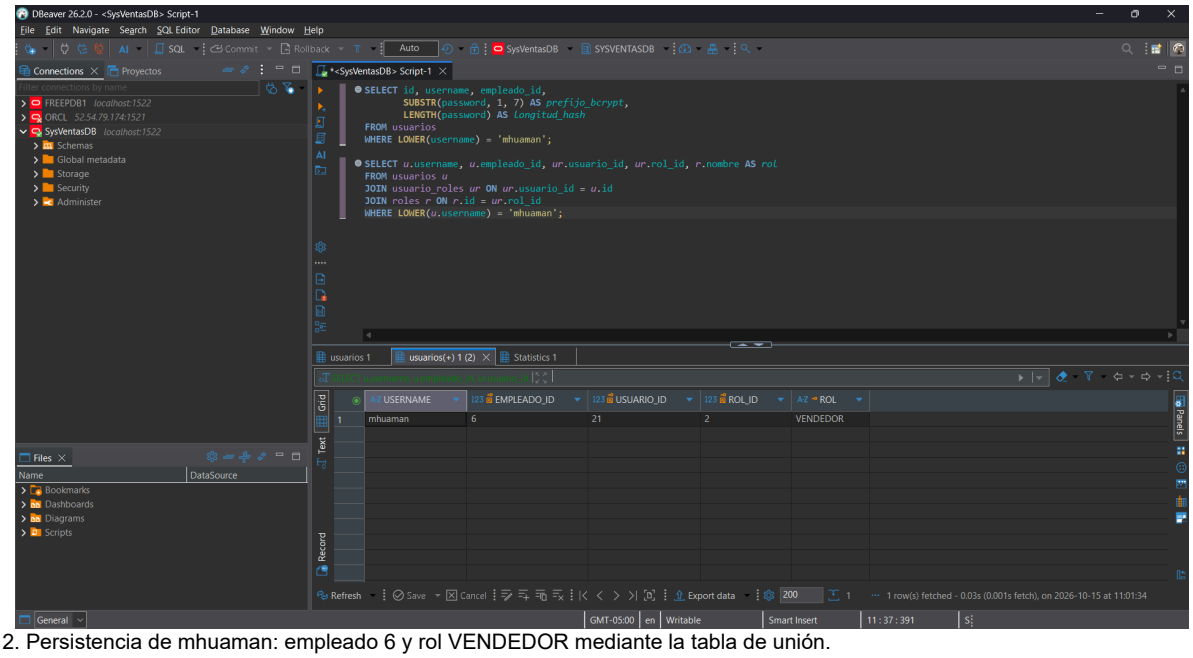


Figura 2. Persistencia de mhuaman: empleado 6 y rol VENDEDOR mediante la tabla de unión.

La cuenta mhuaman se crea para María Huamán Torres con id 21 y empleado 6. Oracle confirma prefijo BCrypt $2a$10$, hash de 60 caracteres y rol 2. Un segundo username para el mismo empleado se rechaza con 409.

3. Resultados de las 24 pruebas

Los códigos esperados de rechazo son resultados correctos de seguridad. La tabla reúne cada caso y el resultado observado en las peticiones y consultas.

Caso	Verificación	Resultado observado
S10-01	Health público	200 sin token.
S10-02	Catálogo sin token	401: debe iniciar sesión.
S10-03	Password incorrecto	401: usuario o contraseña incorrectos.
S10-04	Cuenta inactiva	401 con el mismo mensaje genérico.
S10-05	Username vacío	400 con validationErrors.username.
S10-06	Login vendedor	200, Bearer, 3600 segundos y rol VENDEDOR.
S10-07	Claims locales	sub, authorities, iat y exp; exp - iat = 3600.
S10-08	Perfil autenticado	200; empleado, roles y permisos sin contraseña.
S10-09	Vendedor lee productos	200, respuesta paginada.
S10-10	Vendedor no borra	403 al DELETE de producto.
S10-11	Vendedor registra venta	201: venta 54, Vitamina D x1, S/12.50.
S10-12	Vendedor sin reporte	403 por permiso REPORTES_VER.
S10-13	Almacén no vende	403 al POST de venta.
S10-14	Almacén actualiza catálogo	200 al PUT de producto 134.
S10-15	Administrador ve reporte	200, categorías e importes.
S10-16	Supervisor con dos roles	200 y unión de permisos sin REPORTES_VER.
S10-17	Supervisor vende y edita	201 venta 55 por S/12.50; PUT 200.
S10-18	Supervisor sin reporte	403; ninguno de sus roles concede el permiso.
S10-19	Empleados y roles	200 en ambas consultas; María comienza sin cuenta.
S10-20	Alta y BCrypt	201 mhuaman; hash de 60 caracteres y relación al rol.
S10-21	Empleado con cuenta	409 al intentar mhuaman2 para empleado 6.
S10-22	Rol inexistente	404: Roles no encontrados: [99].
S10-23	Firma alterada	401: El token no es válido.
S10-24	Token expirado	Token de 60 segundos: acceso 200 y posteriormente 401.

4. Resultados y consistencia

Vendedor registró la venta 54 y supervisor la venta 55. Ambas corresponden al cliente 11, producto 133 y cantidad 1: 12.50 x 1 = S/12.50 por venta. Las actualizaciones autorizadas del producto 134 conservaron precio S/18.90 y stock 19. Almacén recibió 403 al intentar vender; vendedor recibió 403 al intentar borrar catálogo.

La cuenta de supervisor demuestra la suma de permisos de sus dos roles sin elevarlos a ADMIN. El administrador accede al reporte, donde la captura muestra Higiene: 10 unidades por S/130.80 y Vitaminas: 10 por S/125.00. Estos valores corresponden al momento de esa consulta.

5. Integridad y expiración del JWT

El JWT ordinario presenta duración de 3600 segundos. La firma alterada devuelve 401. Para la expiración se emitió un token de 60 segundos: en la segunda secuencia de comprobación el acceso inicial devolvió 200 y el acceso posterior devolvió 401 con el mensaje El token ha expirado. Inicie sesión nuevamente. Las comprobaciones repetidas se mantienen dentro del mismo caso.

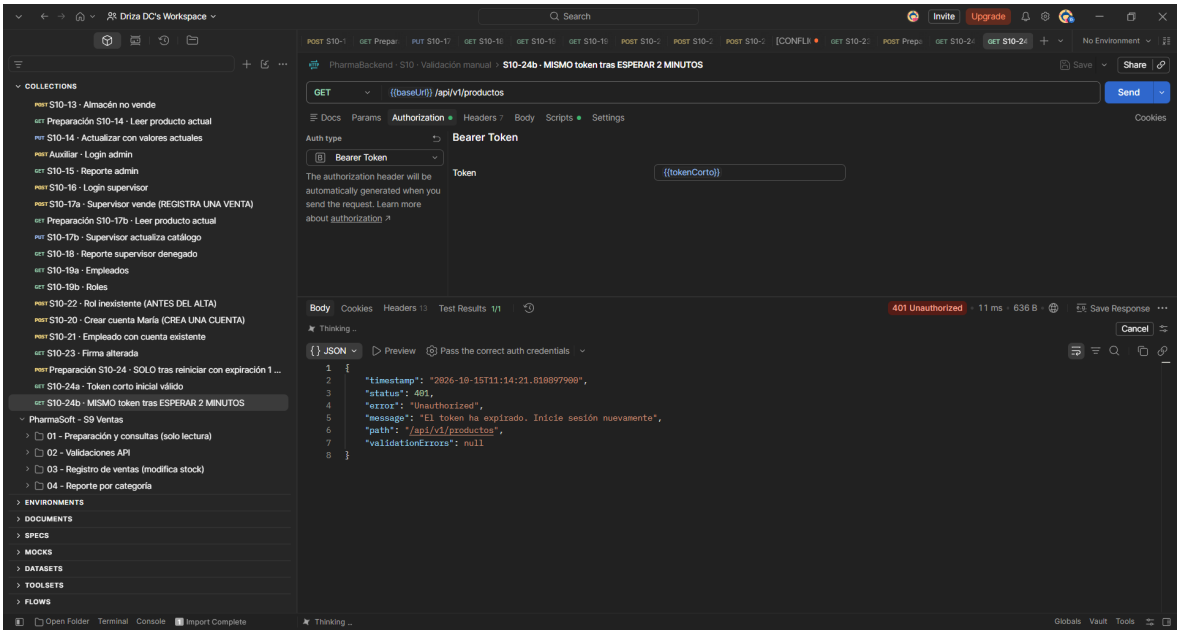


Figura 3. El acceso con token corto vencido responde 401 con un mensaje específico de expiración.

6. Persistencia, pruebas y conclusiones

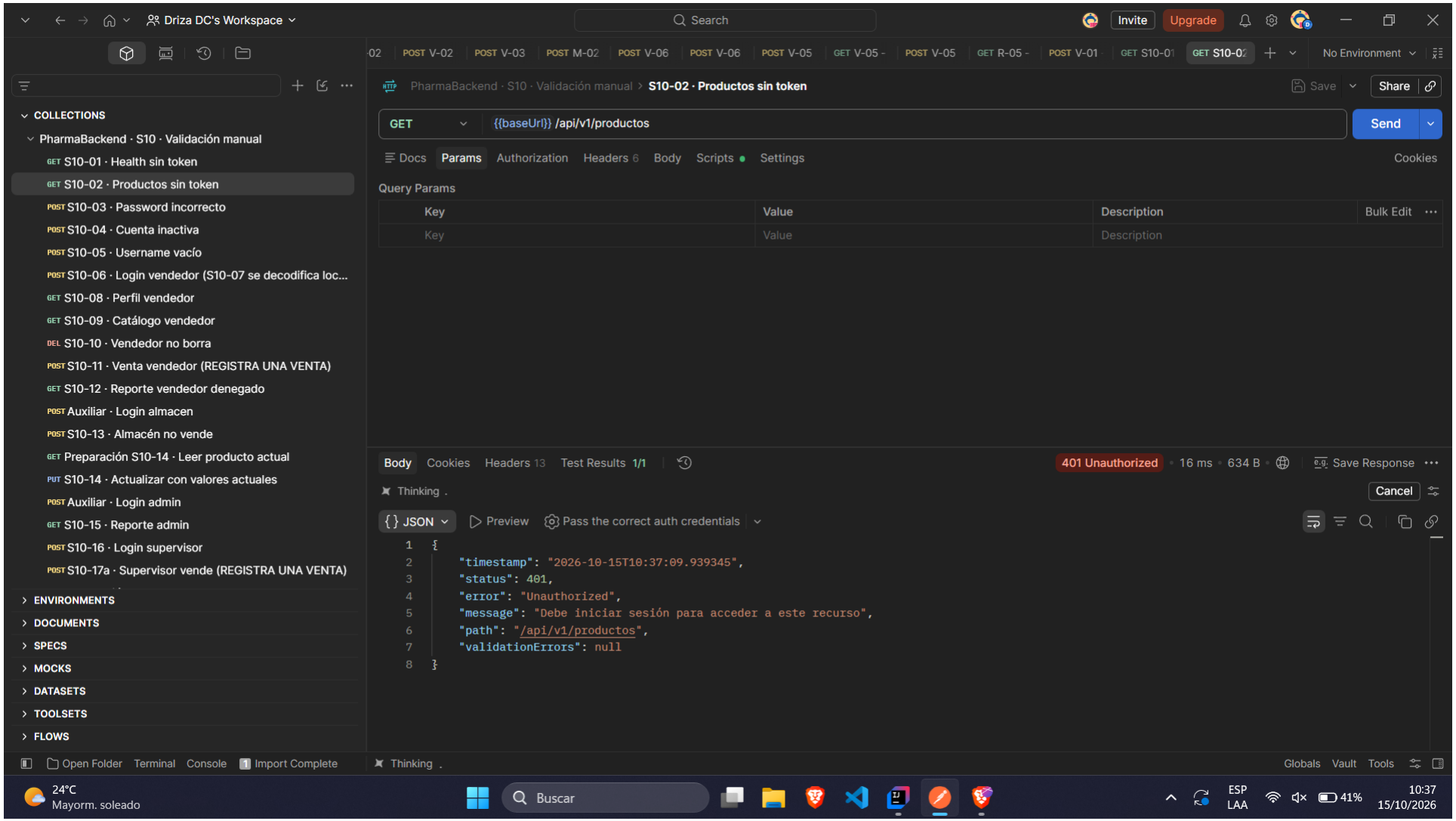
El historial Flyway muestra baseline de versión 1 y migración V2 seguridad aplicada con éxito. Las pruebas unitarias de JwtService y PermisosPorRol ejecutan nueve casos sin fallos, errores ni omisiones. La API distingue autenticación y autorización, aplica permisos a cada operación y mantiene las relaciones de cuenta, empleado y roles. Las evidencias siguientes se organizan por aspecto, conservando las secuencias de validación.

Evidencias

Autenticación y acceso público

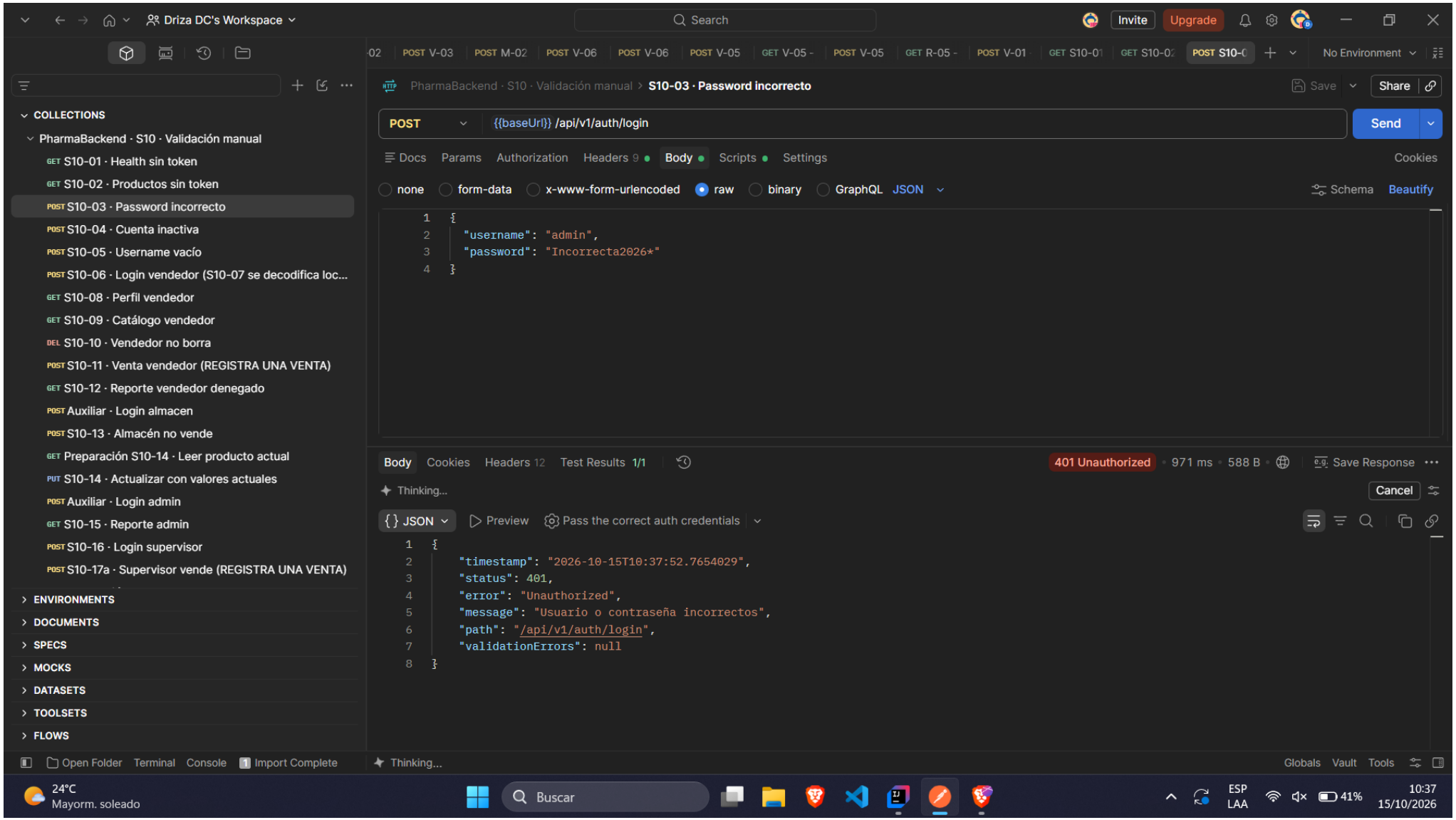
S10-02 · Catálogo sin token

GET productos devuelve 401 y el mensaje Debe iniciar sesión para acceder a este recurso.



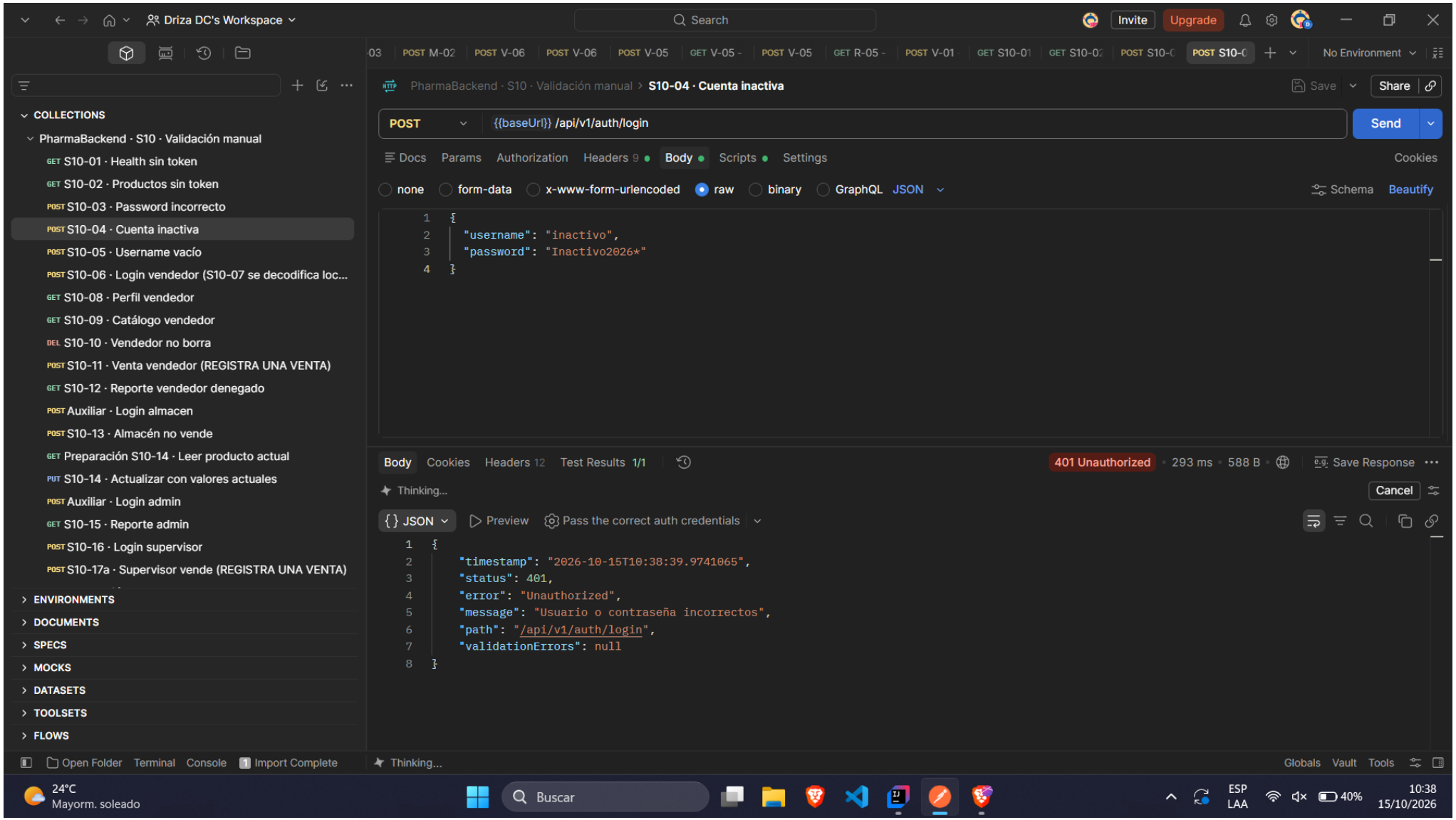
S10-03 · Contraseña incorrecta

Login de admin con contraseña incorrecta: 401 y mensaje genérico de credenciales.



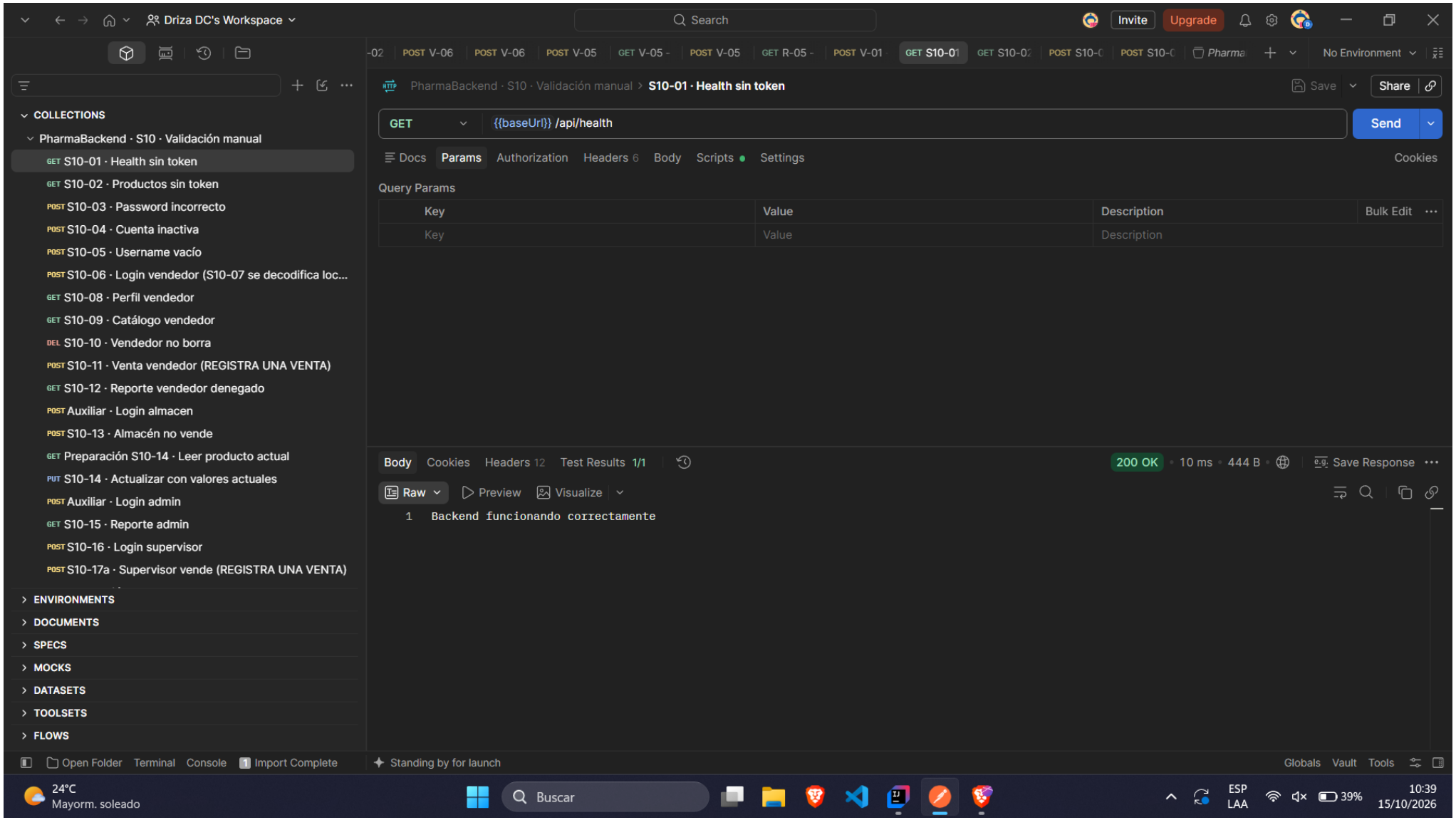
S10-04 · Cuenta inactiva

Login de inactivo: 401 con el mismo mensaje de credenciales incorrectas.



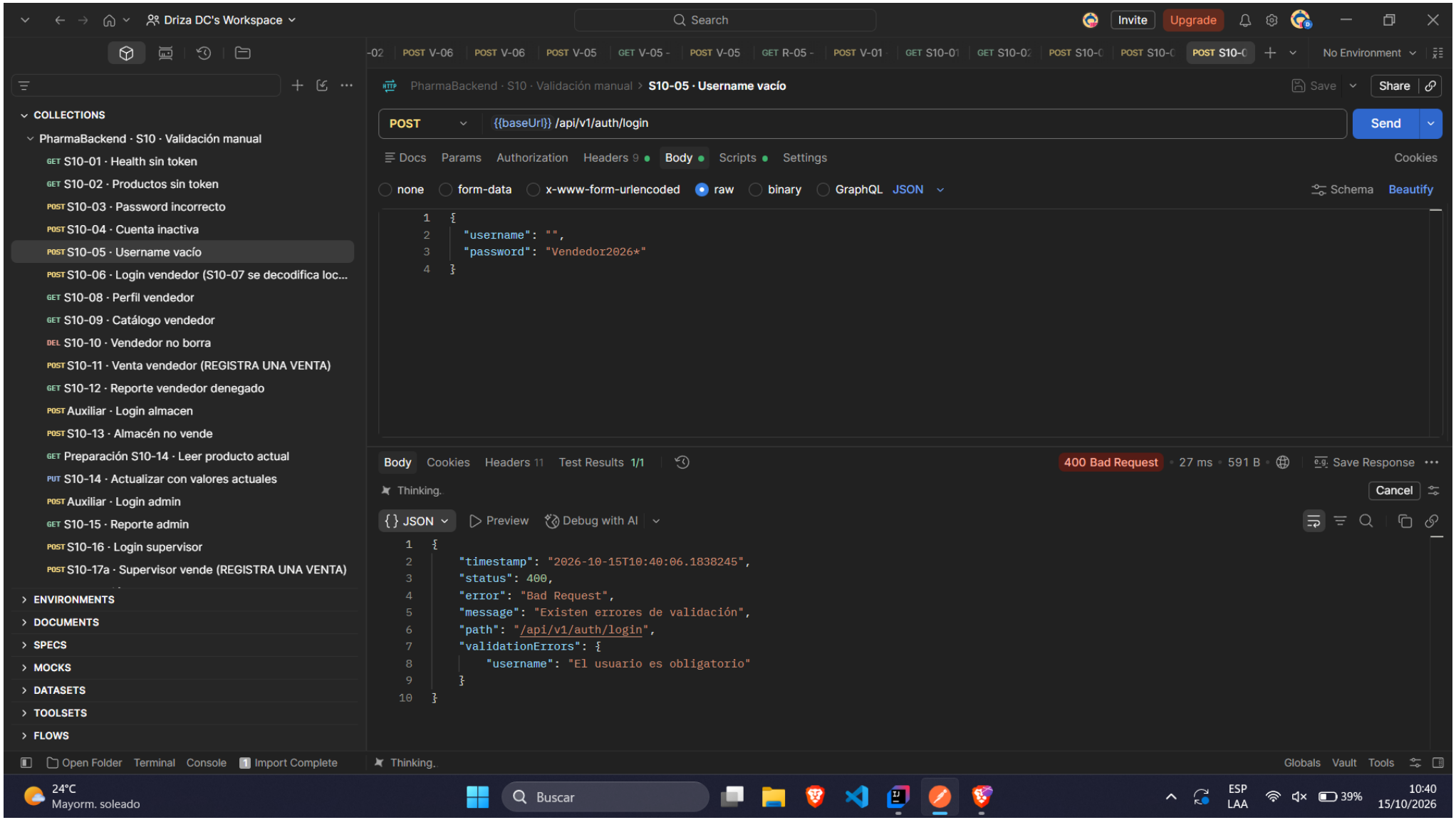
S10-01 · Health público

GET /api/health responde 200 y confirma el funcionamiento del backend sin autenticación.



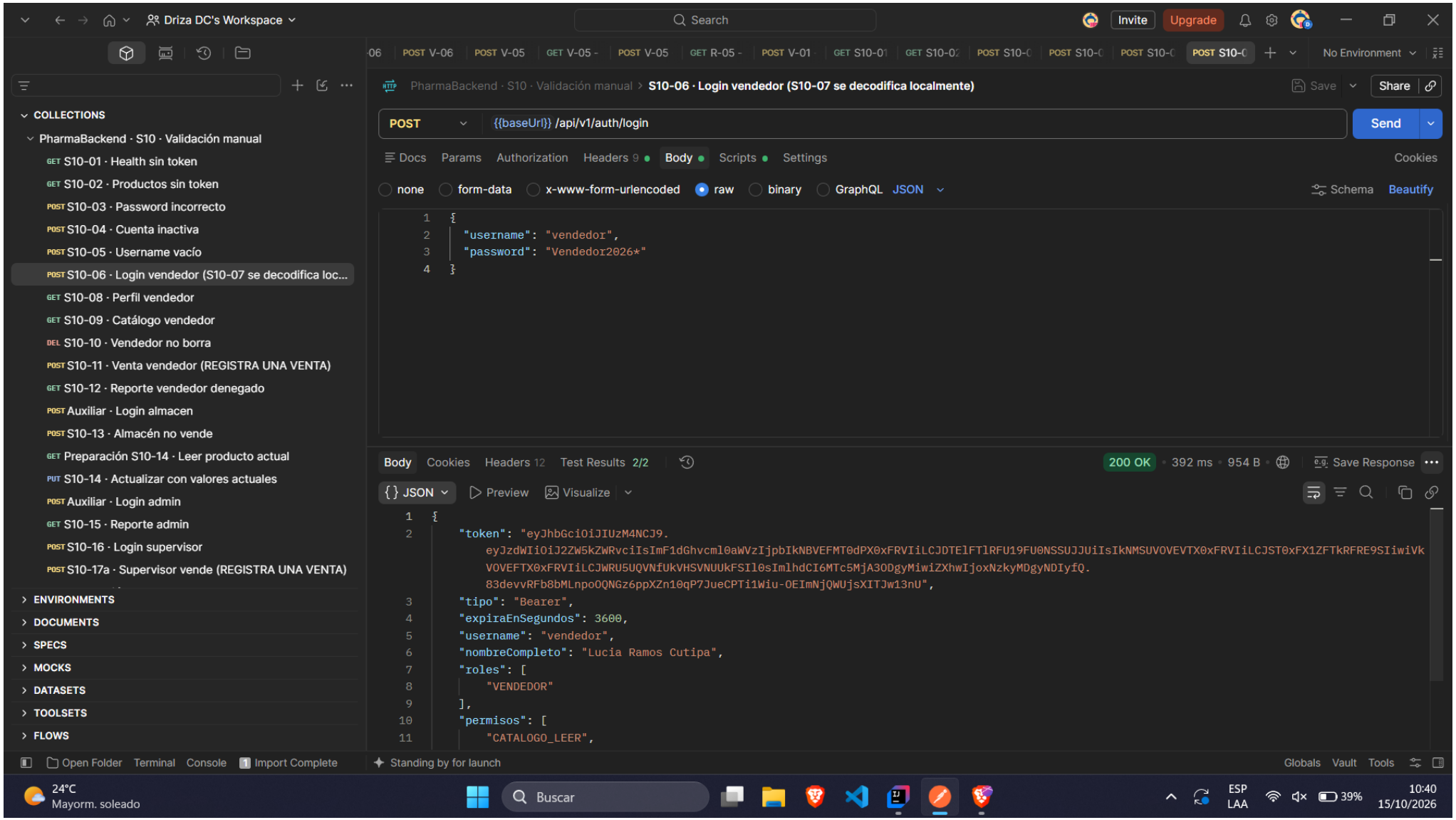
S10-05 · Username obligatorio

Username vacío: 400 con validationErrors.username y el mensaje El usuario es obligatorio.



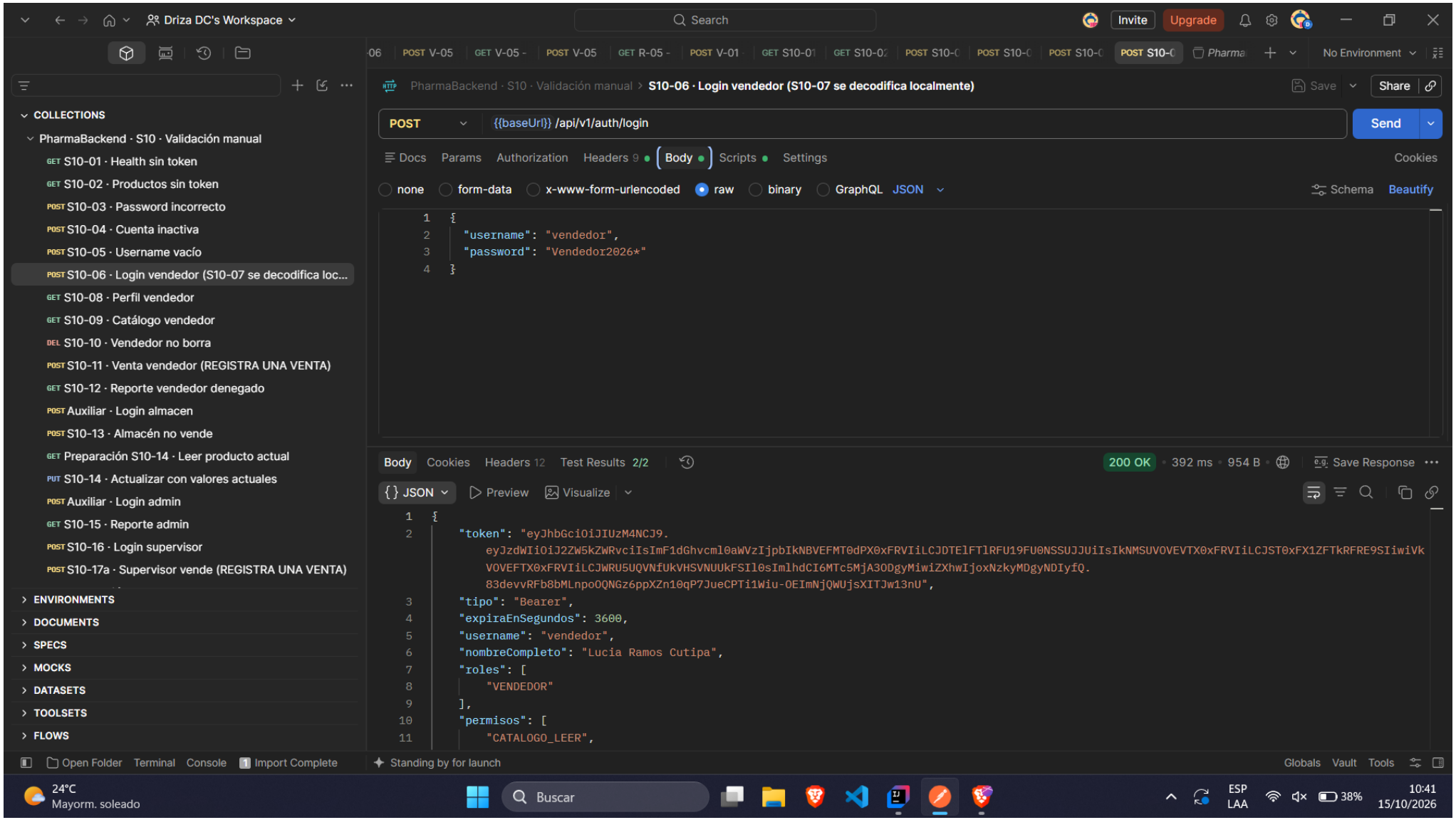
S10-06 · Login vendedor

Respuesta 200 con JWT Bearer, duración 3600 segundos, username vendedor y rol VENDEDOR.



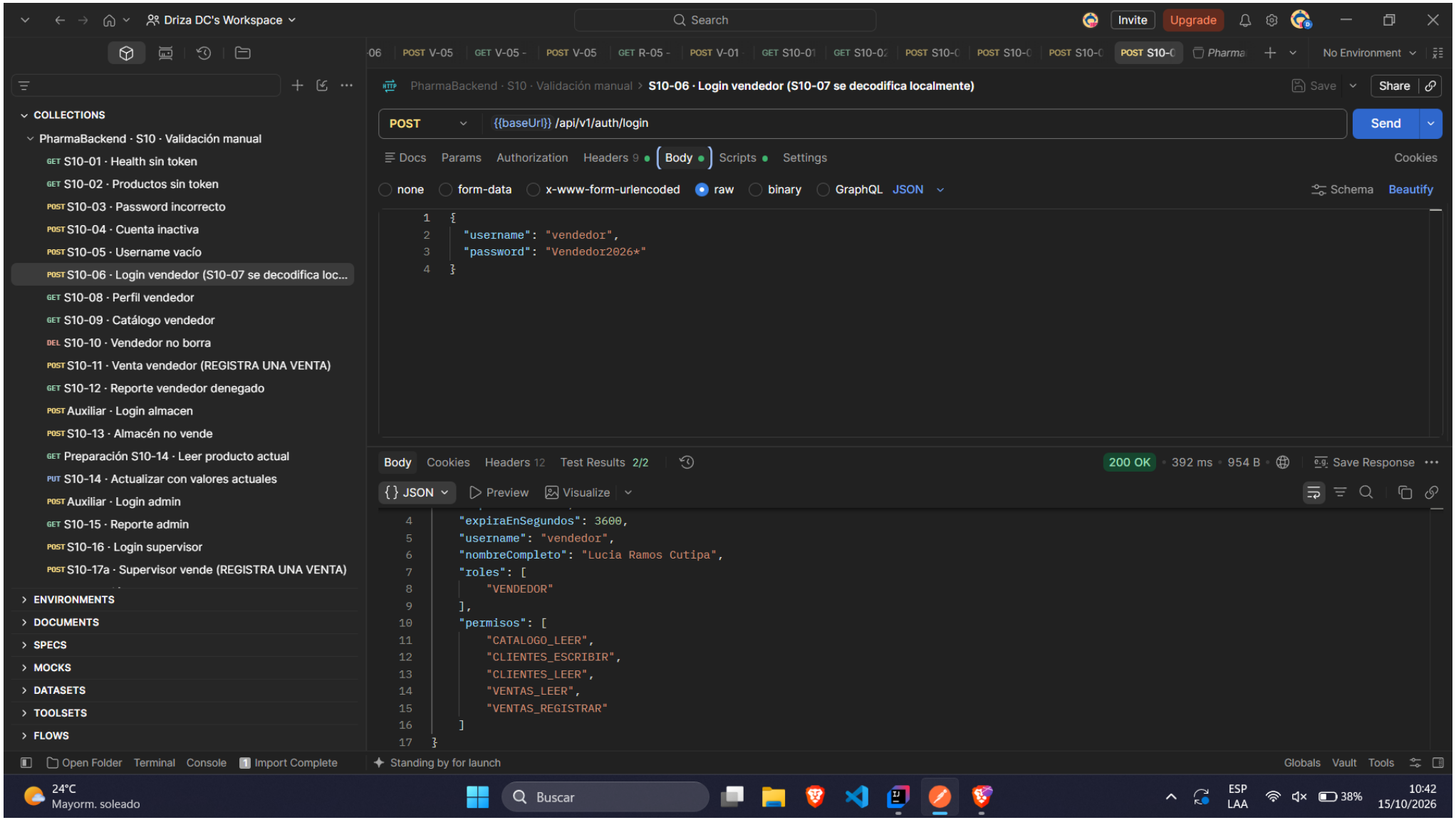
S10-06 · Login vendedor: comprobación adicional

Nueva respuesta 200 de login vendedor con token y sus datos de autenticación.



S10-06 · Permisos del vendedor

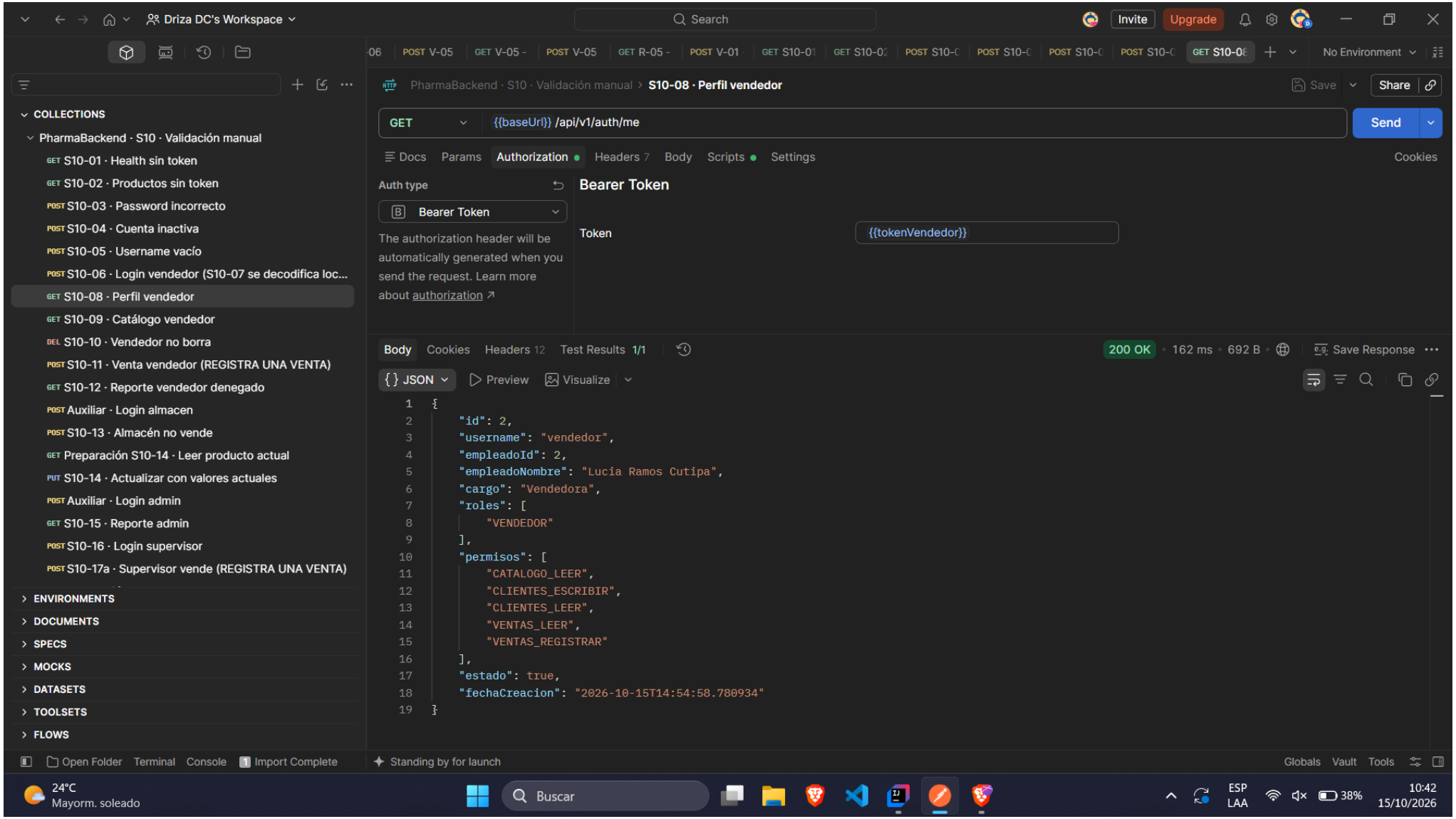
Vista completa de los cinco permisos del vendedor: catálogo de lectura, clientes y ventas.



JWT y perfil autenticado

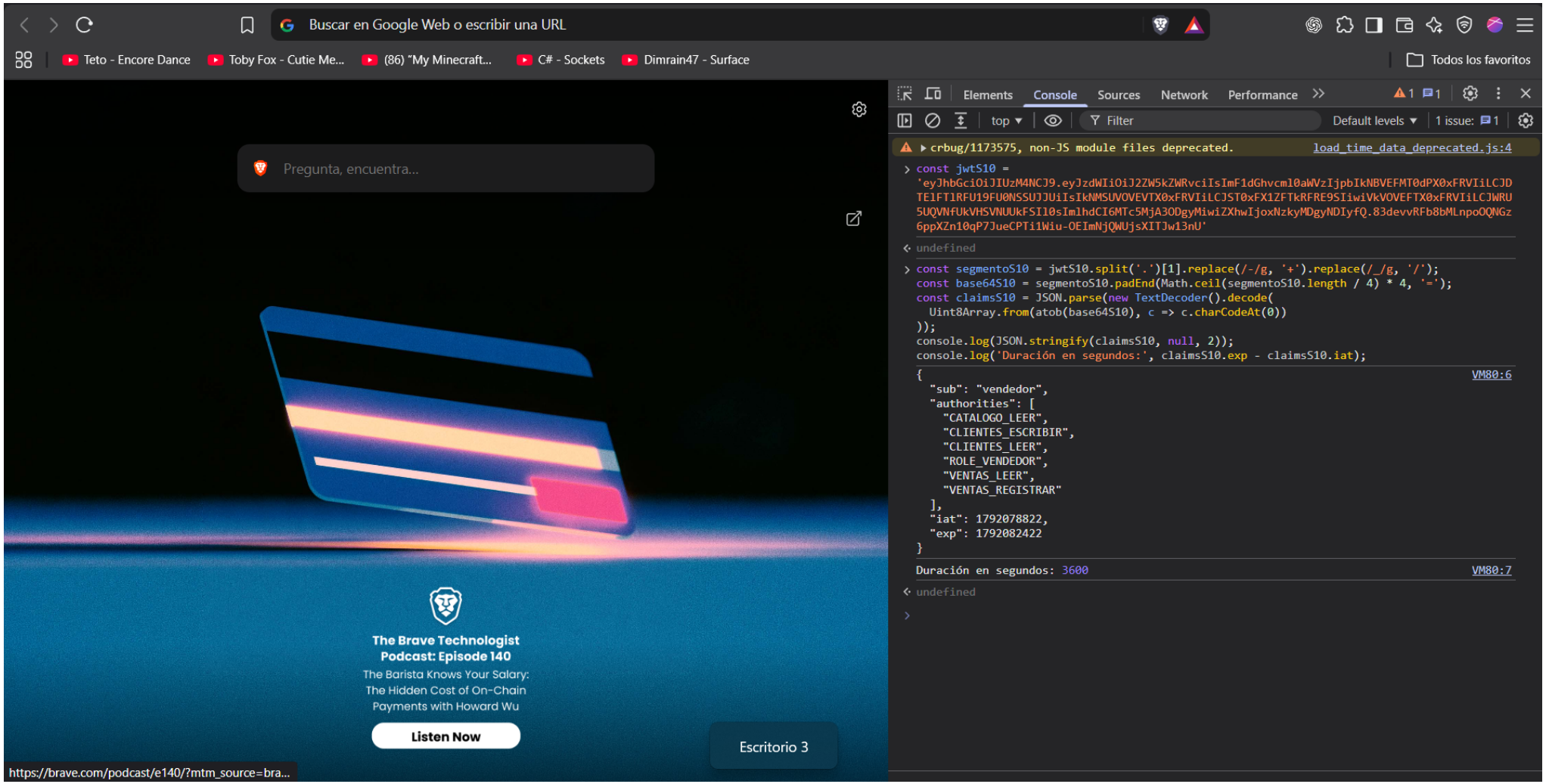
S10-08 · Perfil del usuario autenticado

GET auth/me con tokenVendedor devuelve 200 y datos del empleado, roles y permisos, sin contraseña.



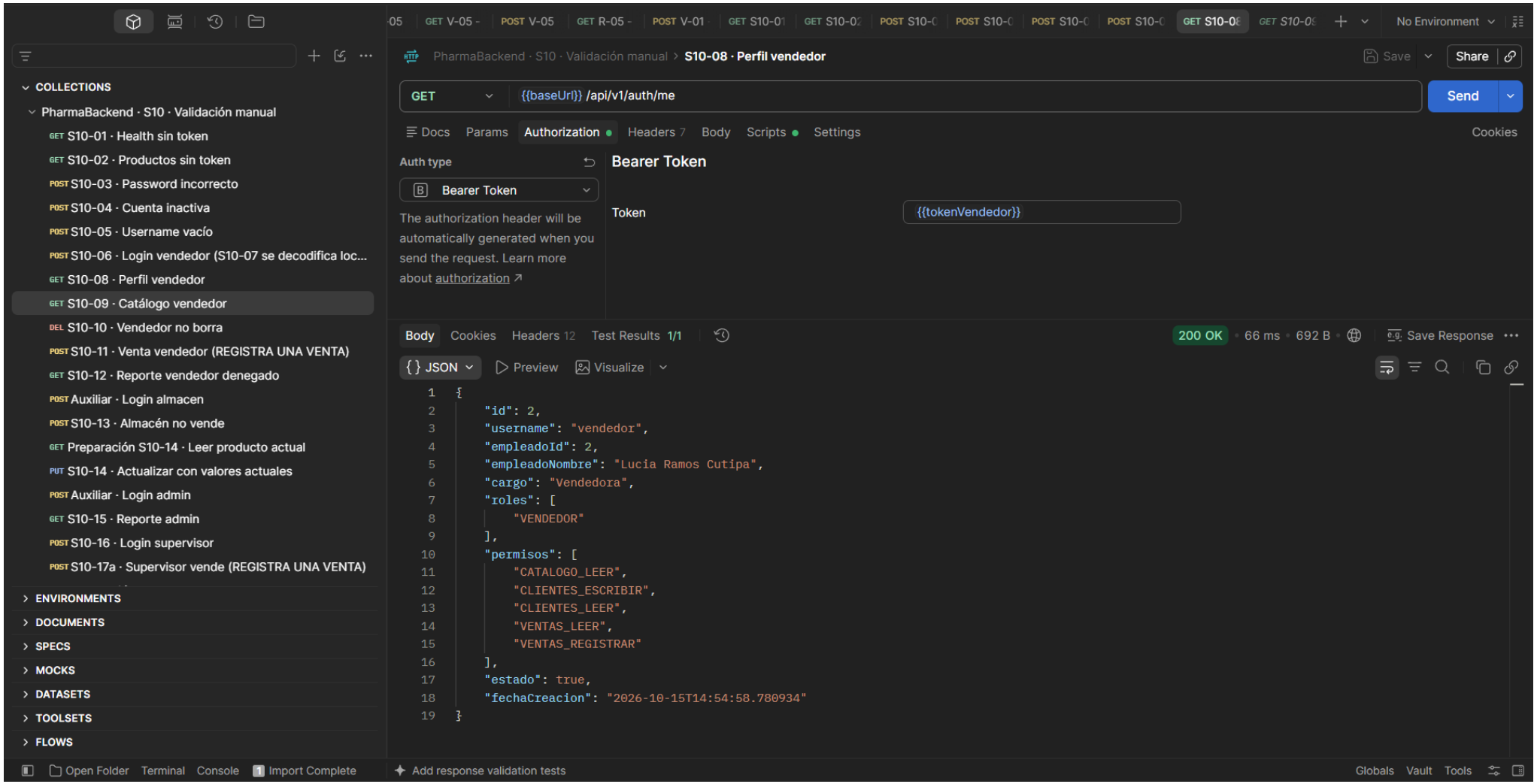
S10-07 · Claims y duración del JWT

Decodificación local: sub vendedor, authorities, iat, exp y diferencia de 3600 segundos.



S10-08 · Perfil autenticado: comprobación adicional

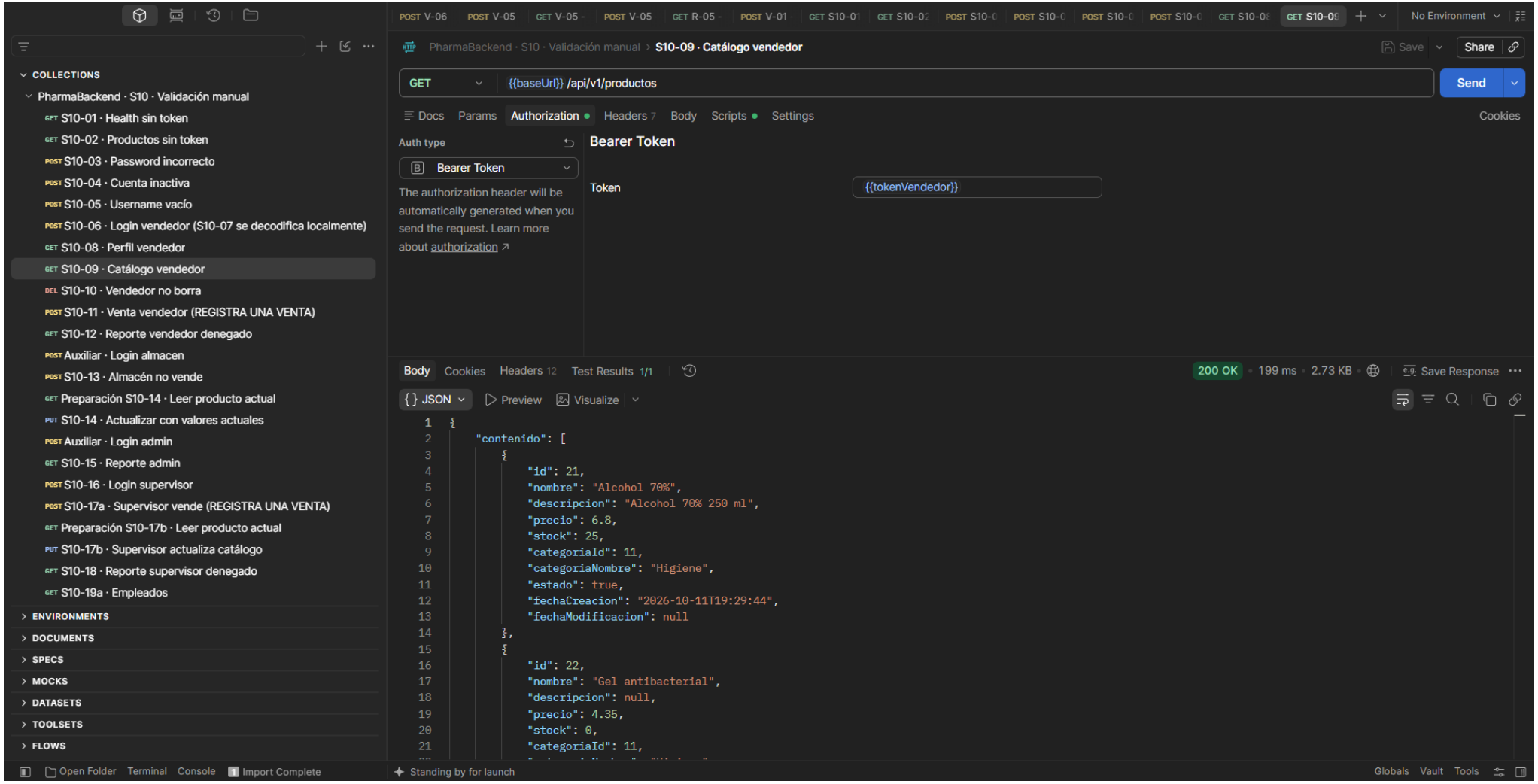
La respuesta de auth/me presenta el perfil plano y los permisos efectivos del vendedor.



Permisos por rol

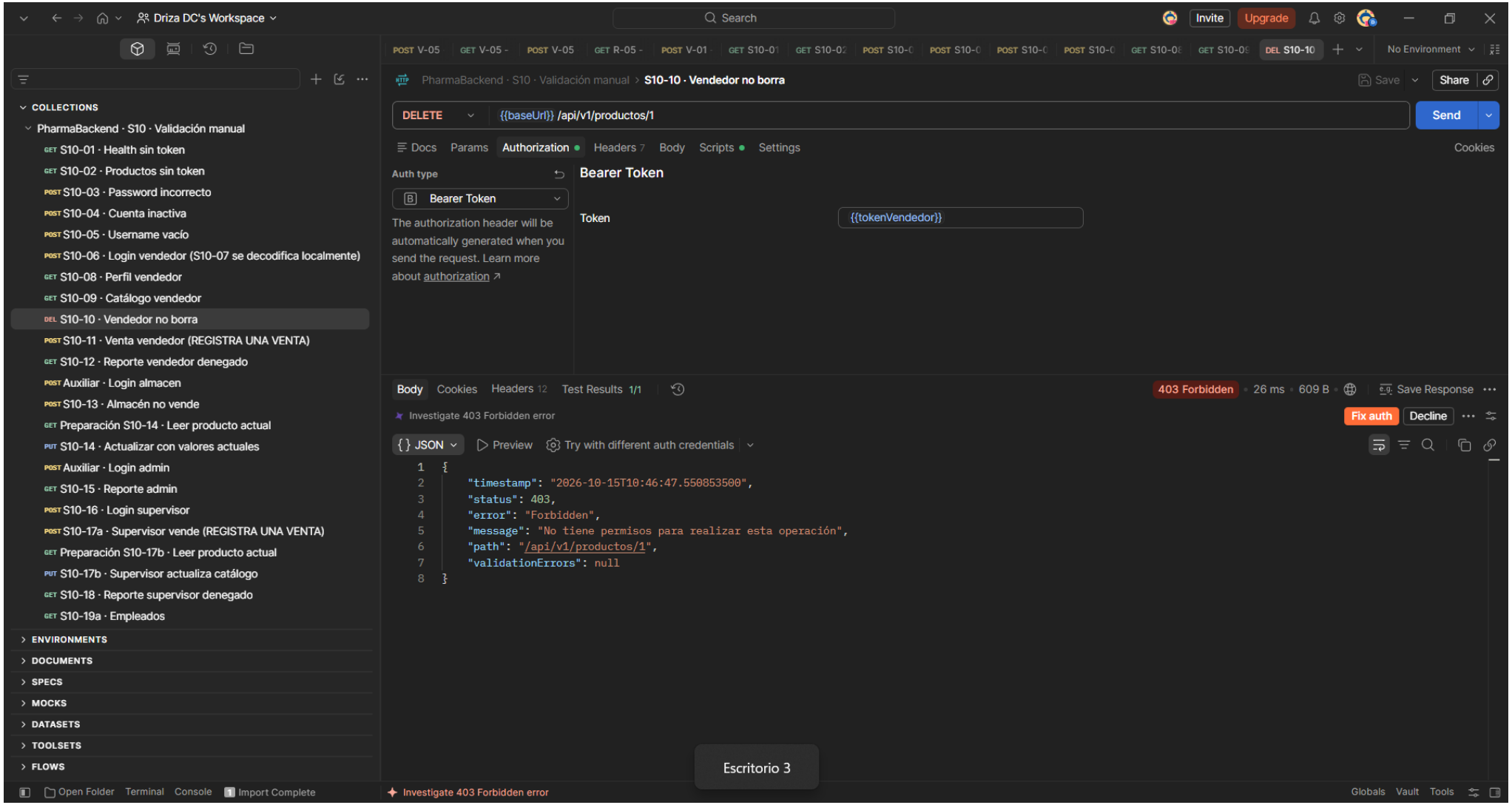
S10-09 · Lectura de catálogo permitida

Vendedor obtiene 200 y contenido paginado de productos.



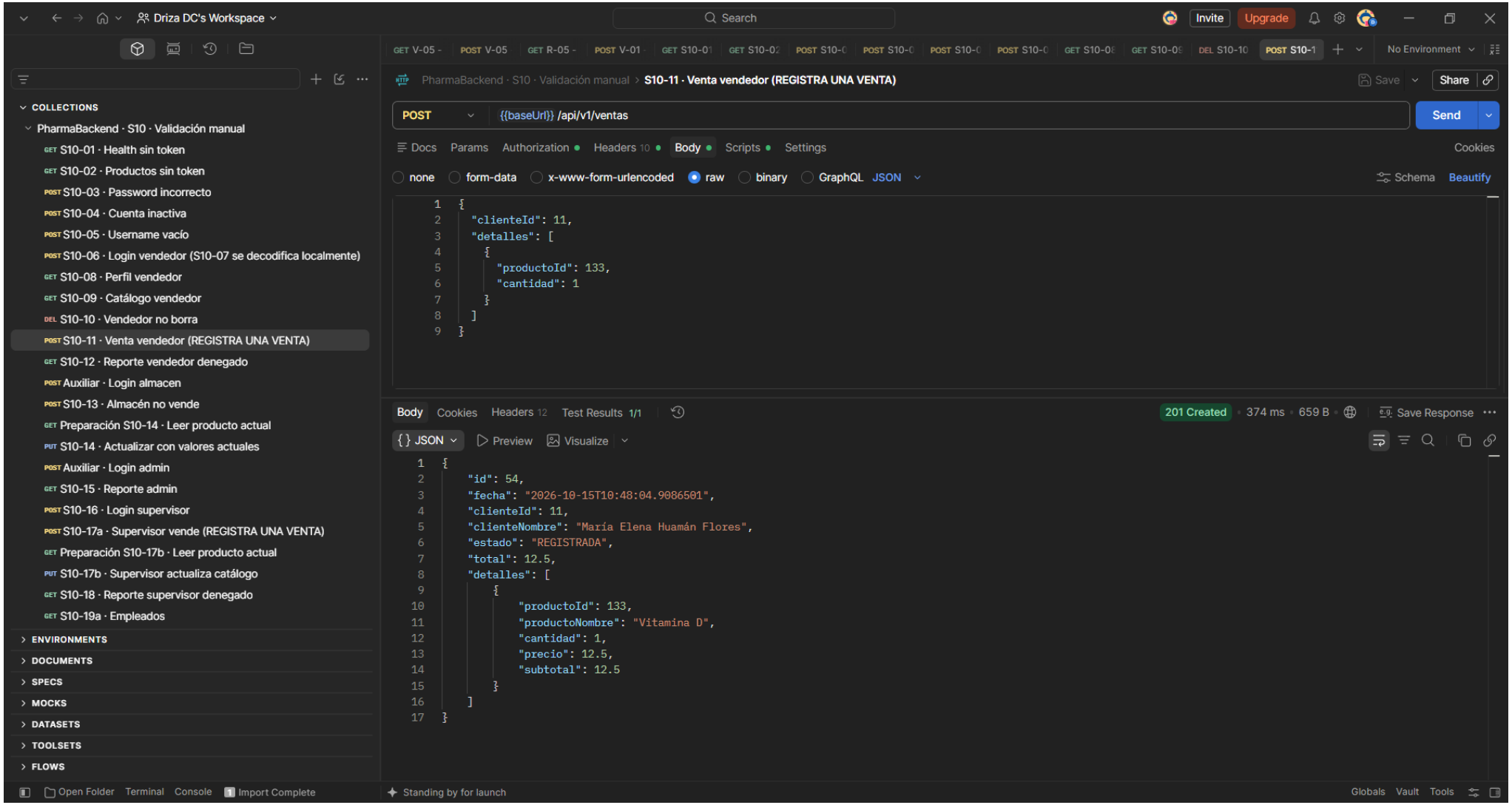
S10-10 · Borrado de catálogo denegado

DELETE productos/1 con token vendedor responde 403: No tiene permisos para realizar esta operación.



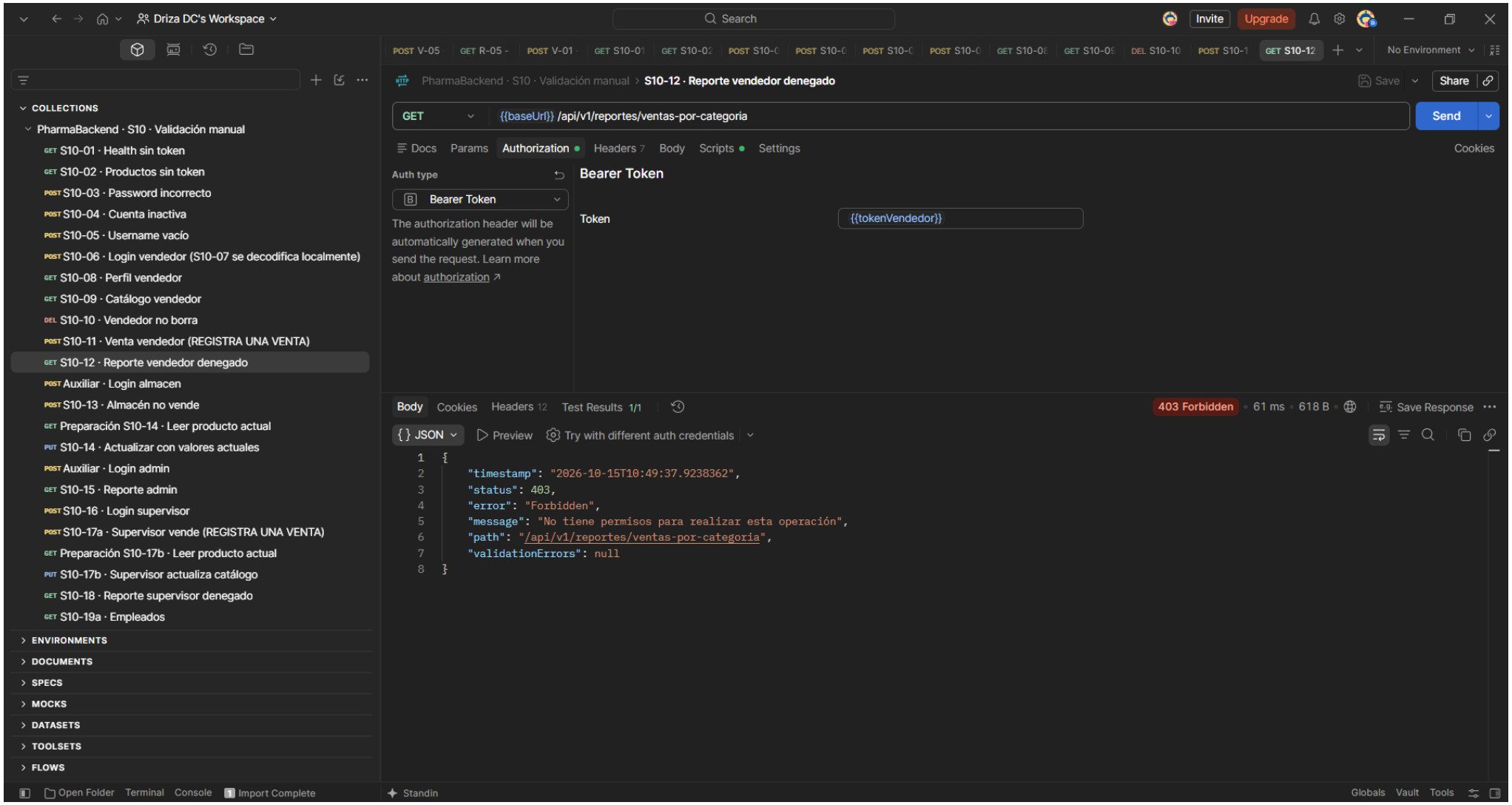
S10-11 · Venta registrada por vendedor

POST ventas crea la venta 54: Vitamina D x1, precio y total S/12.50, estado REGISTRADA, HTTP 201.



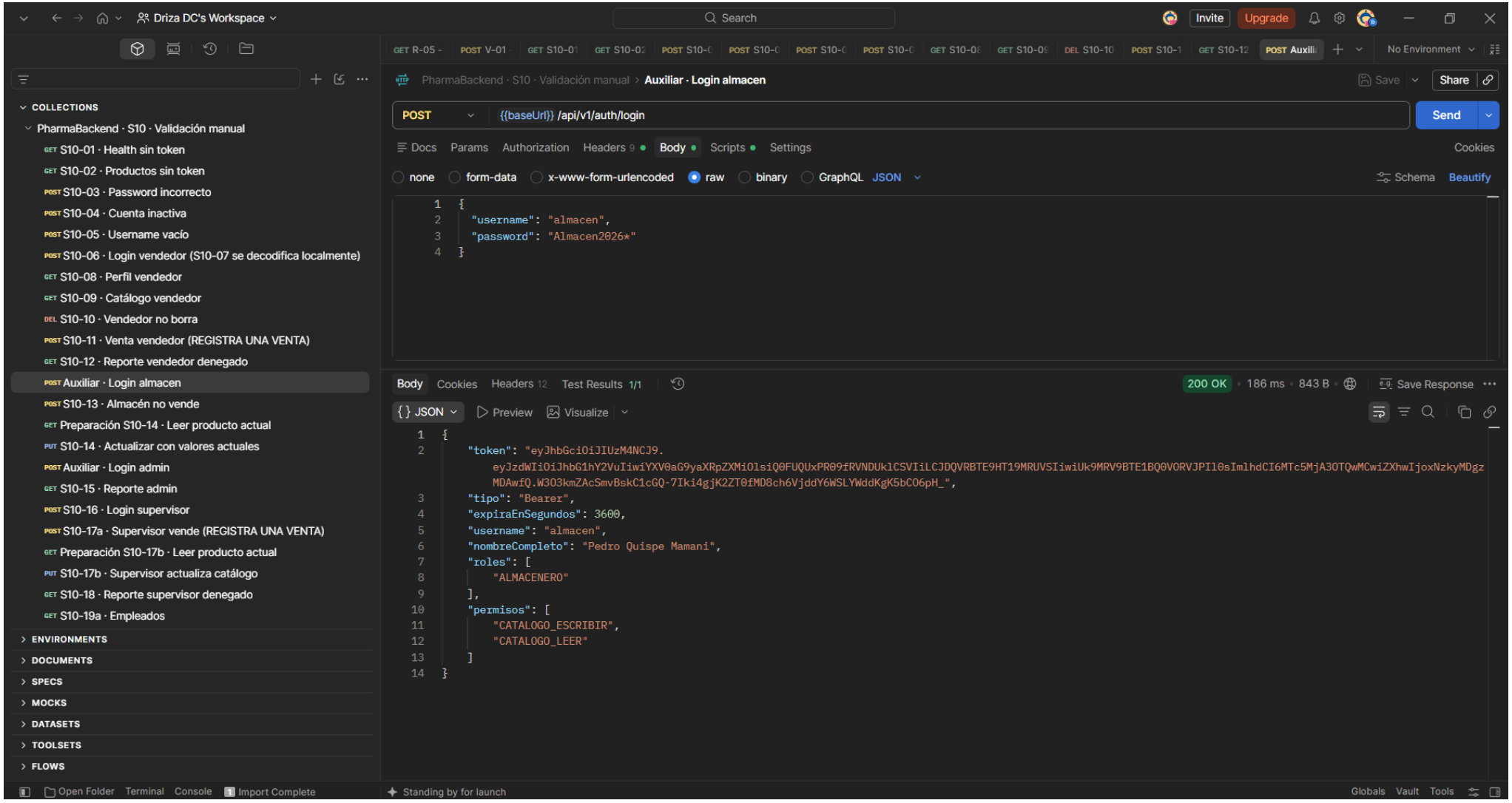
S10-12 · Reporte denegado al vendedor

El token del vendedor recibe 403 al consultar el reporte de ventas por categoría.



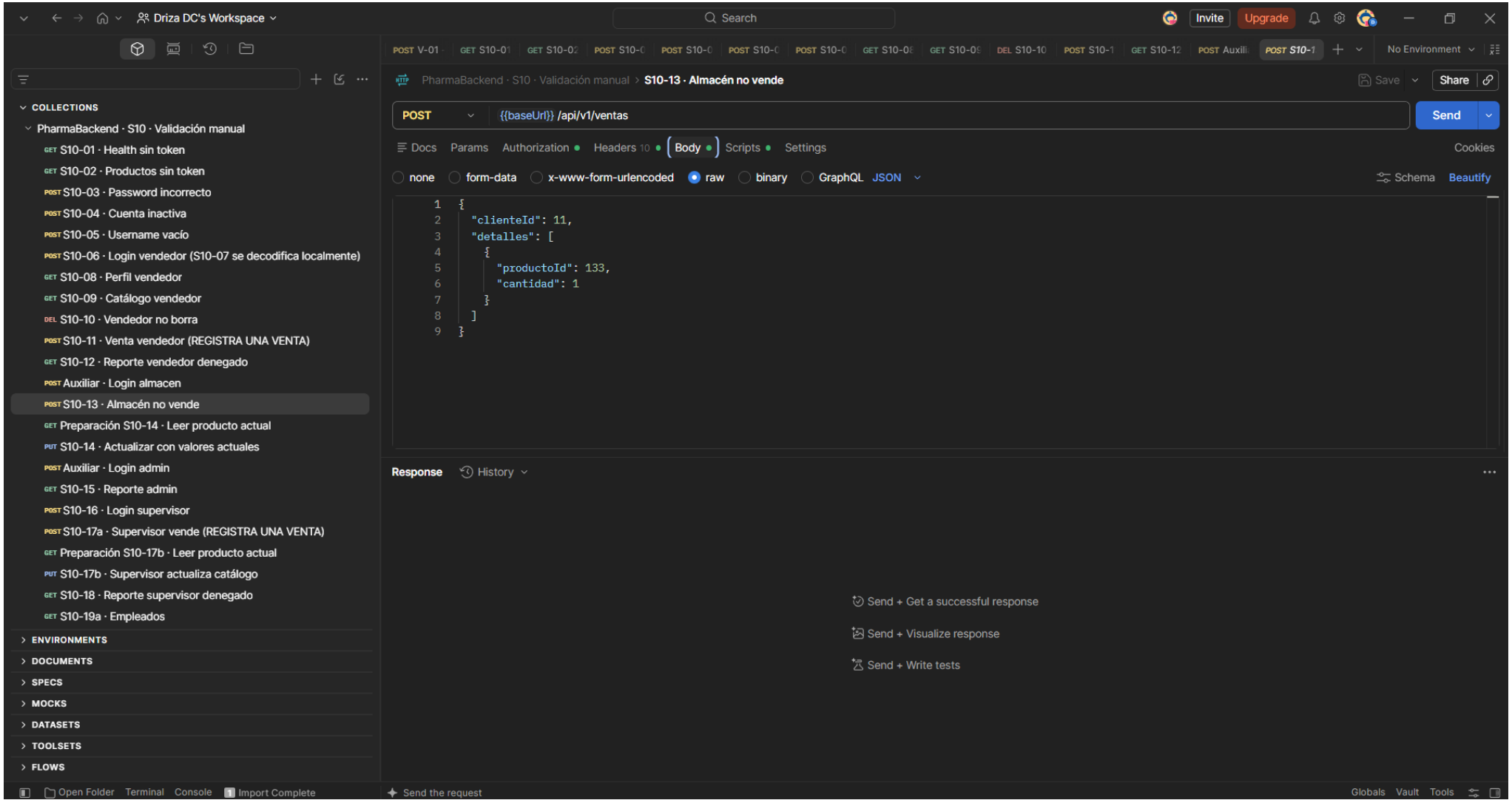
Autenticación de almacén

Login de almacen responde 200 con rol ALMACENERO y permisos CATALOGO_ESCRIBIR y CATALOGO_LEER.



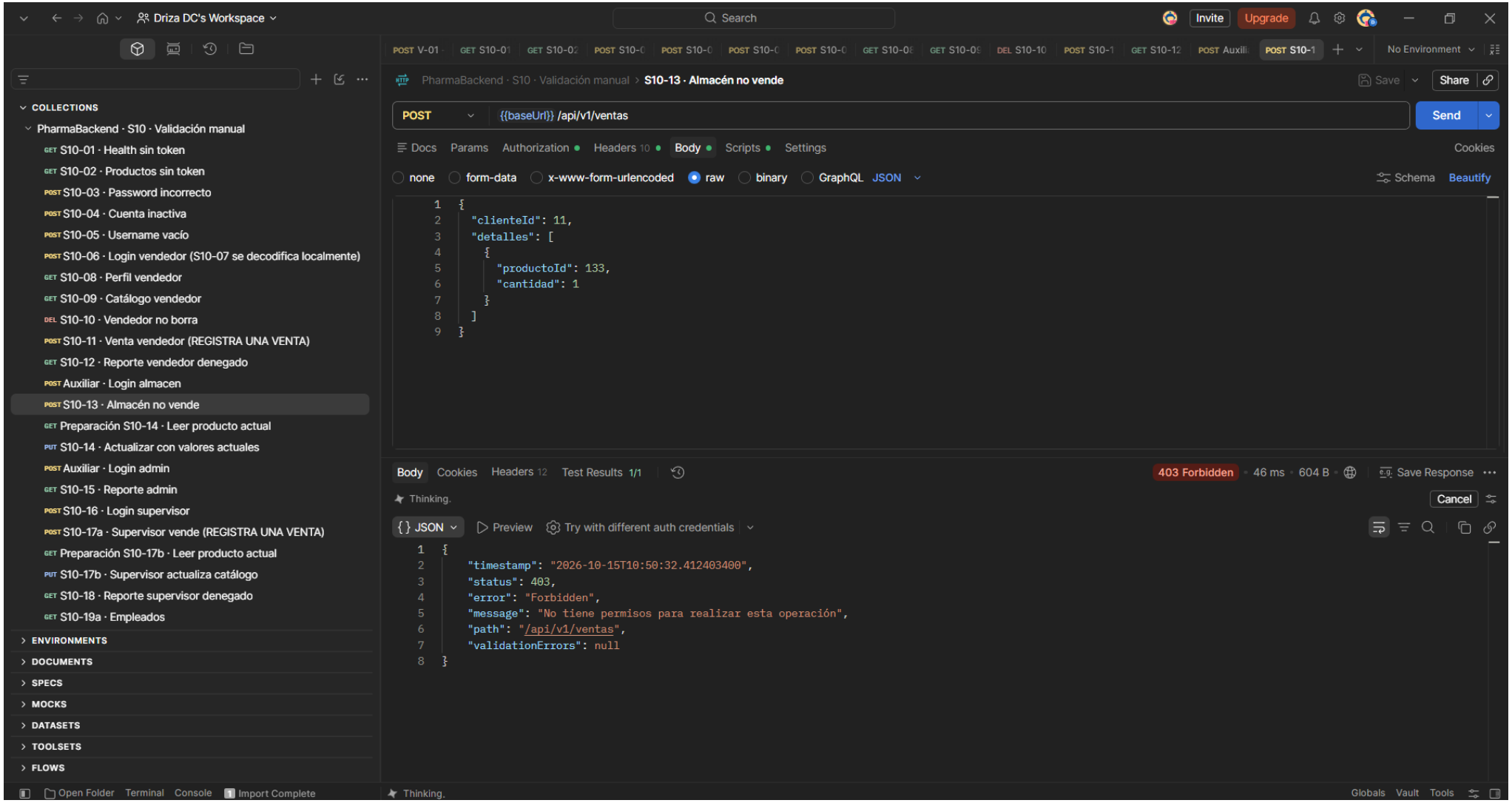
S10-13 · Solicitud de venta desde almacén

Preparación del Body: cliente 11 y producto 133, cantidad 1, antes de enviar la solicitud.



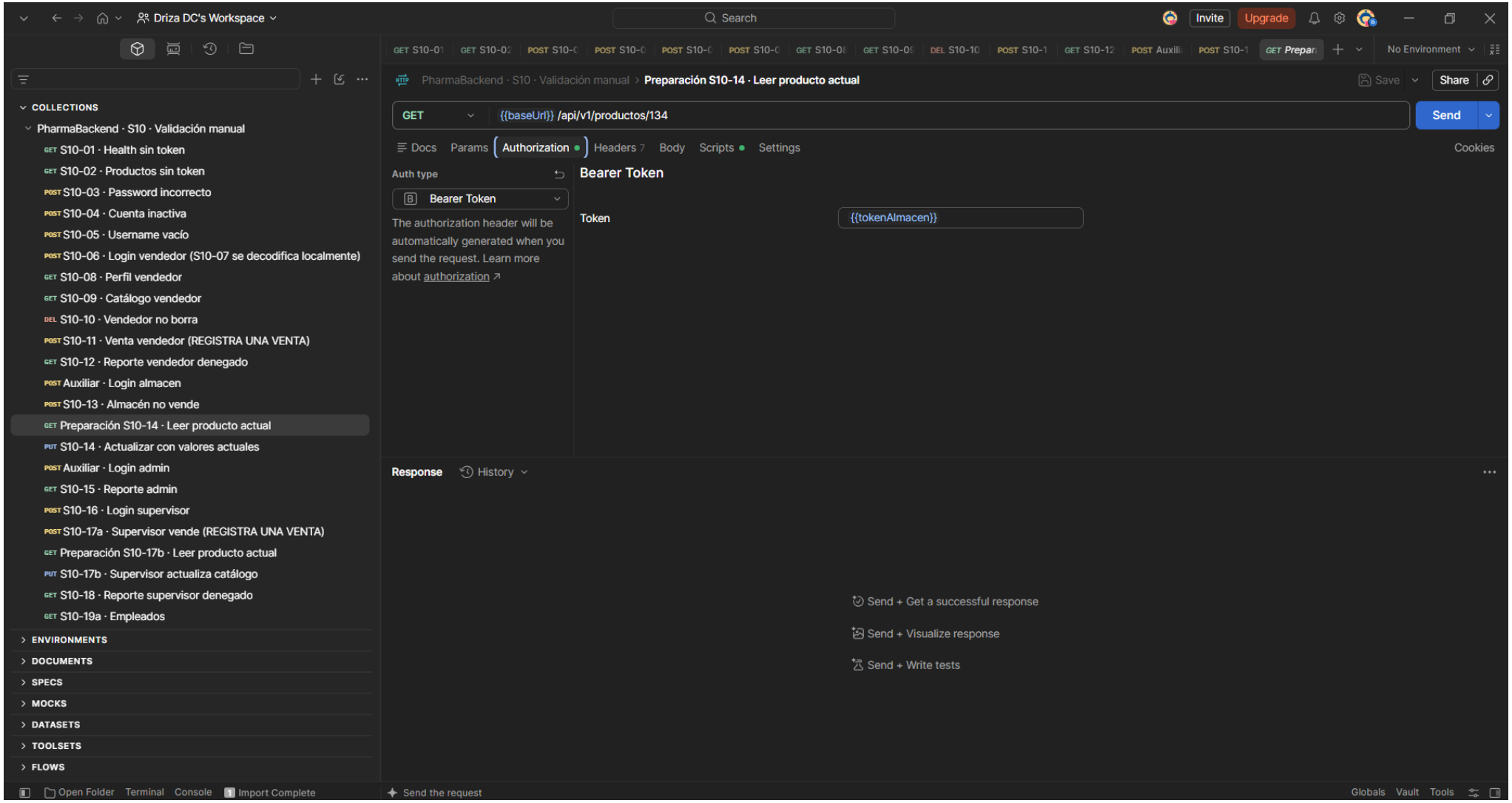
S10-13 · Venta denegada a almacén

El POST de ventas enviado como almacen recibe 403, sin registrar la operación.



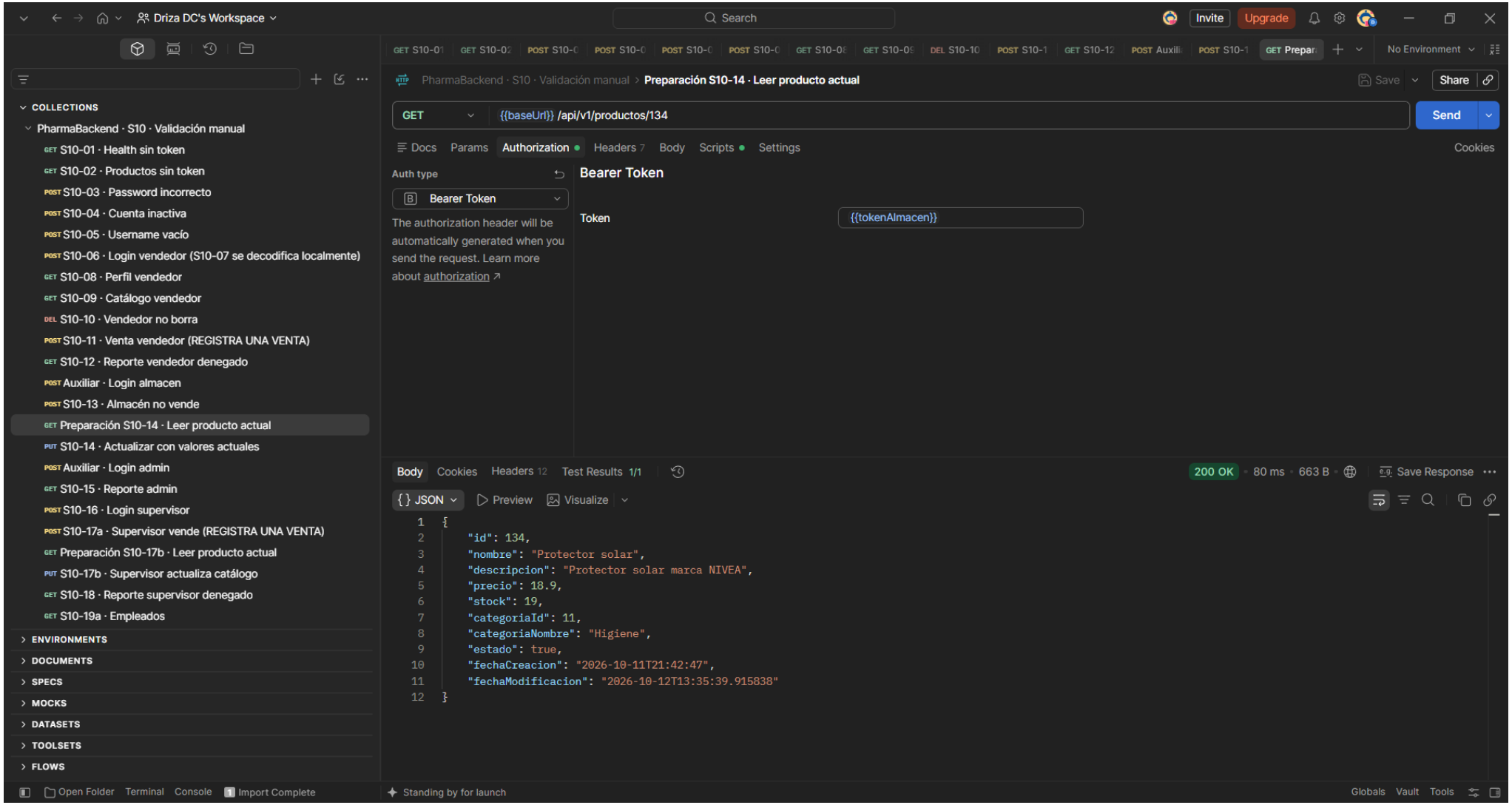
S10-14 · Preparación de lectura del producto

GET productos/134 configurado con tokenAlmacen antes de obtener los valores actuales.



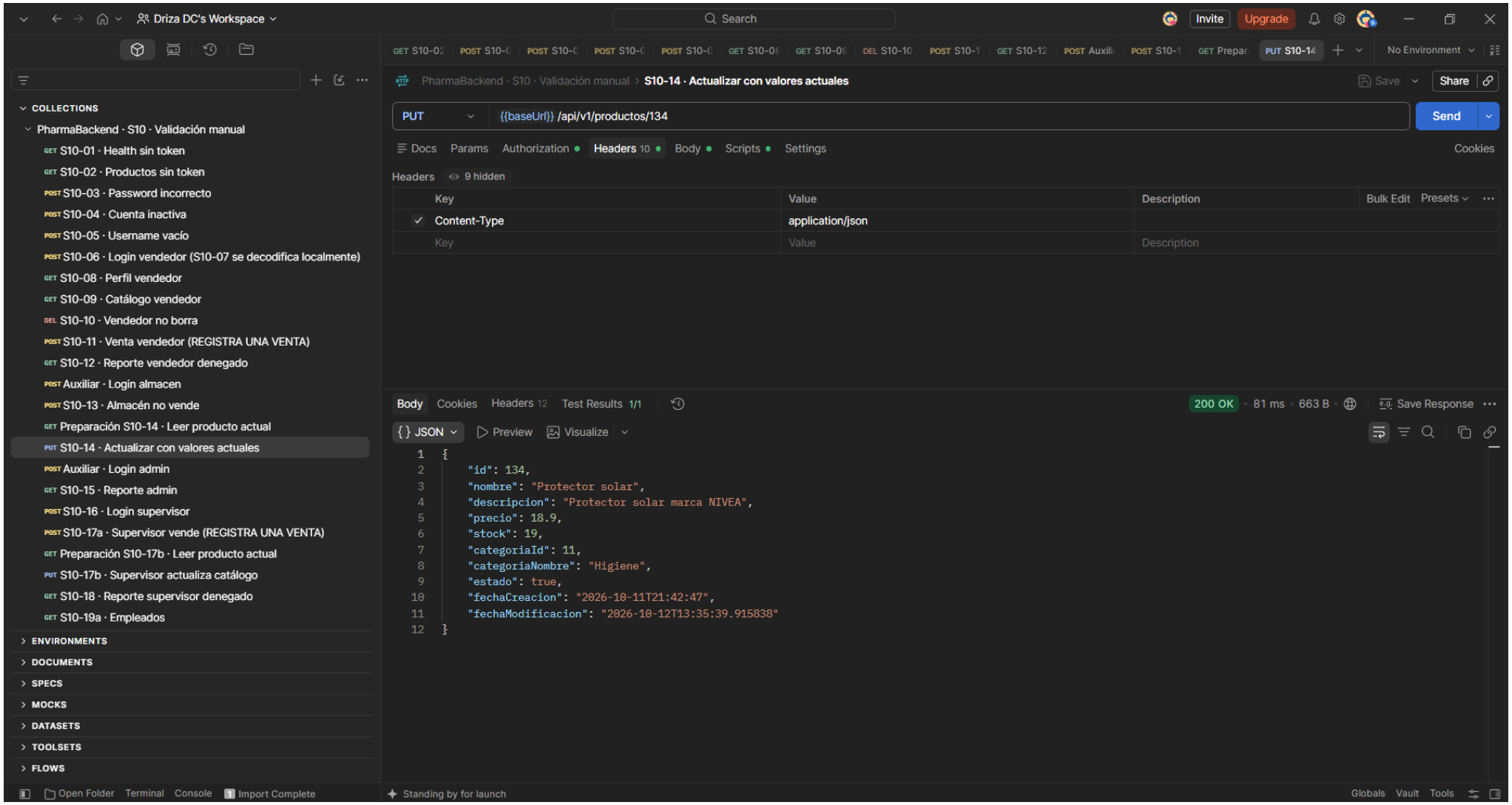
S10-14 · Lectura actual del producto

Protector solar: GET 200, precio S/18.90, stock 19, categoría Higiene y estado activo.



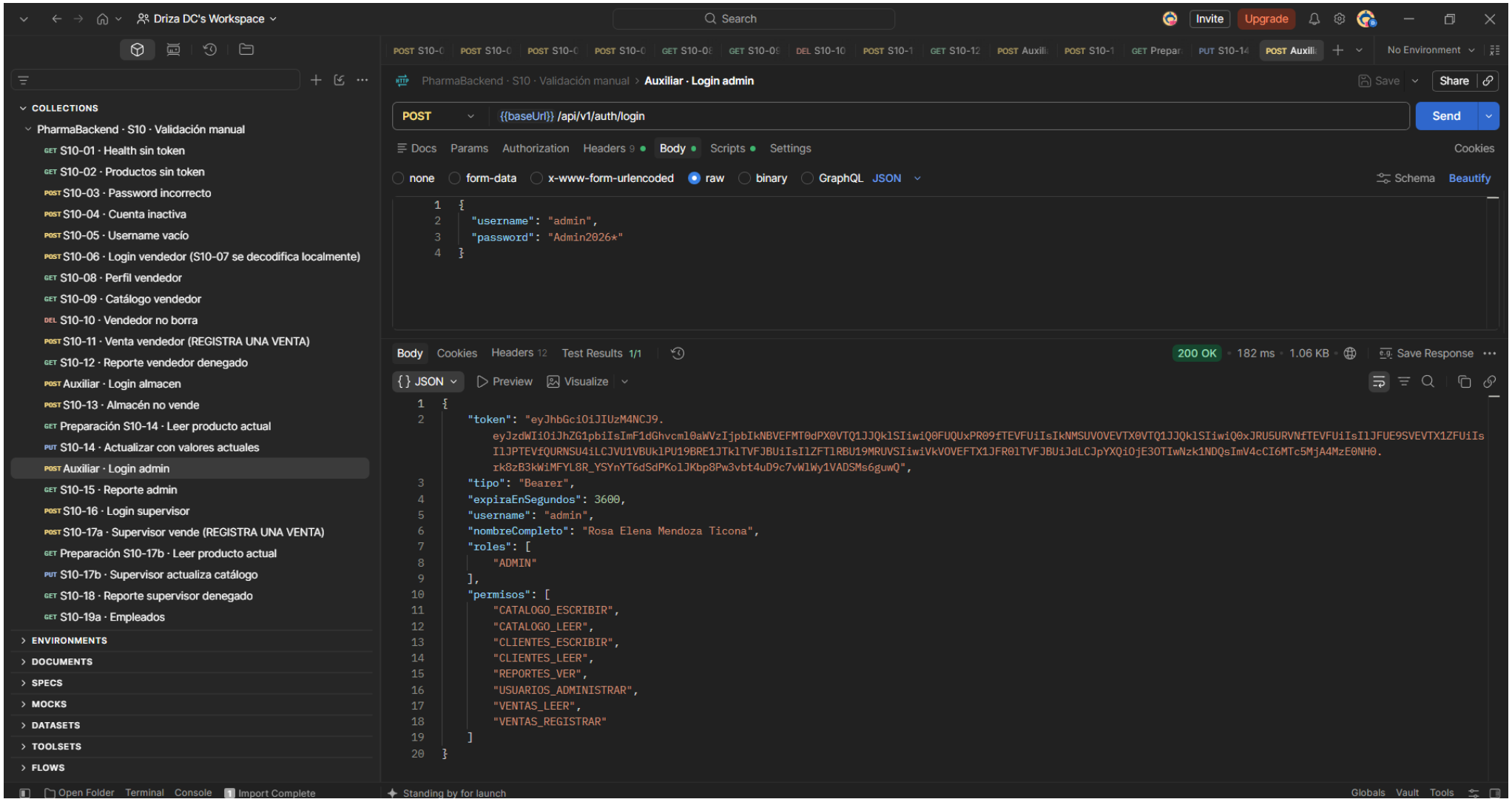
S10-14 · Actualización permitida a almacén

PUT productos/134 responde 200 y conserva los valores comerciales del producto.



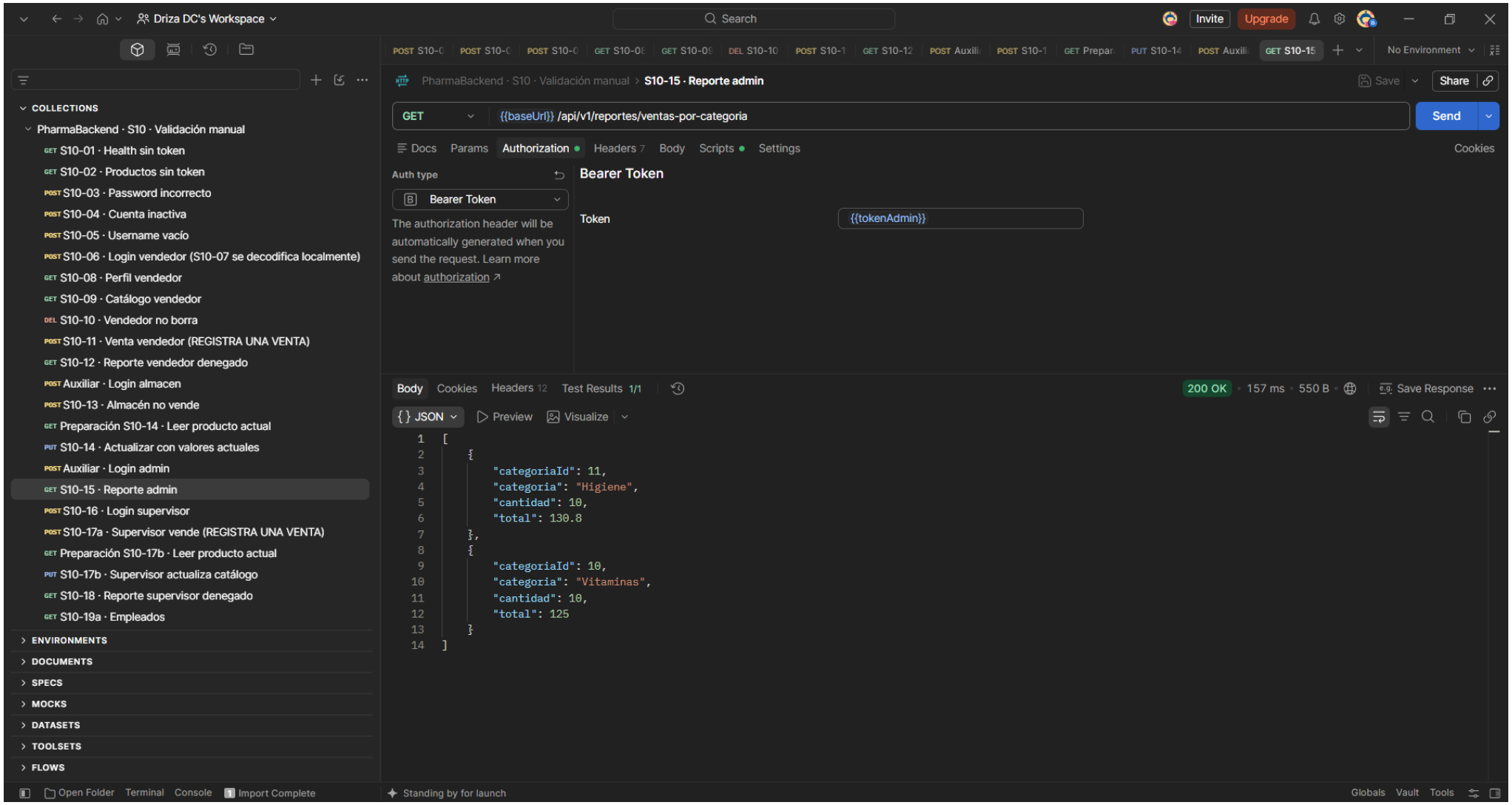
Autenticación de administrador

Login admin: 200, rol ADMIN y los ocho permisos de la aplicación.



S10-15 · Reporte permitido al administrador

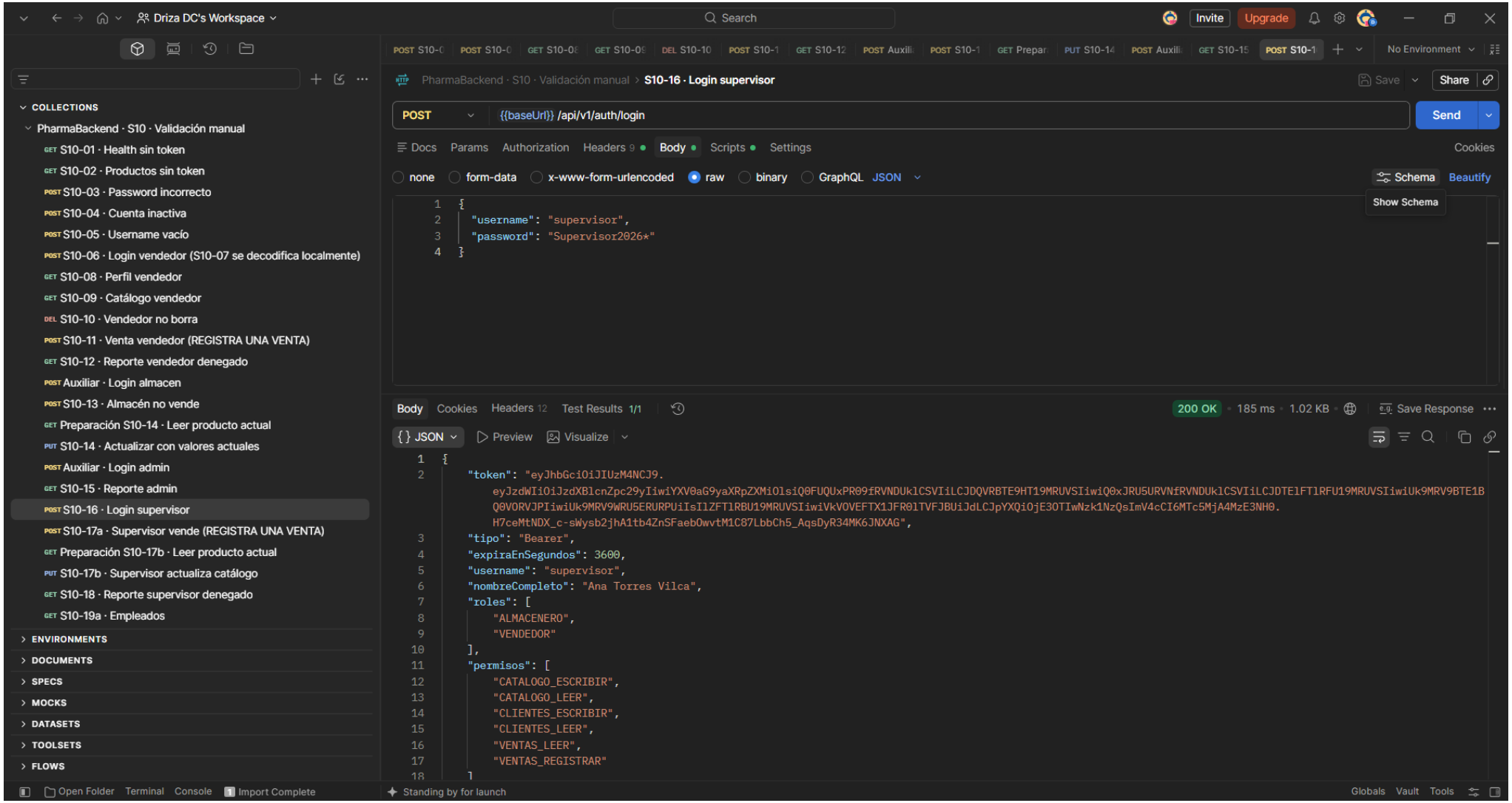
GET del reporte con tokenAdmin responde 200: Higiene 10 unidades por S/130.80 y Vitaminas 10 por S/125.00.



Roles múltiples

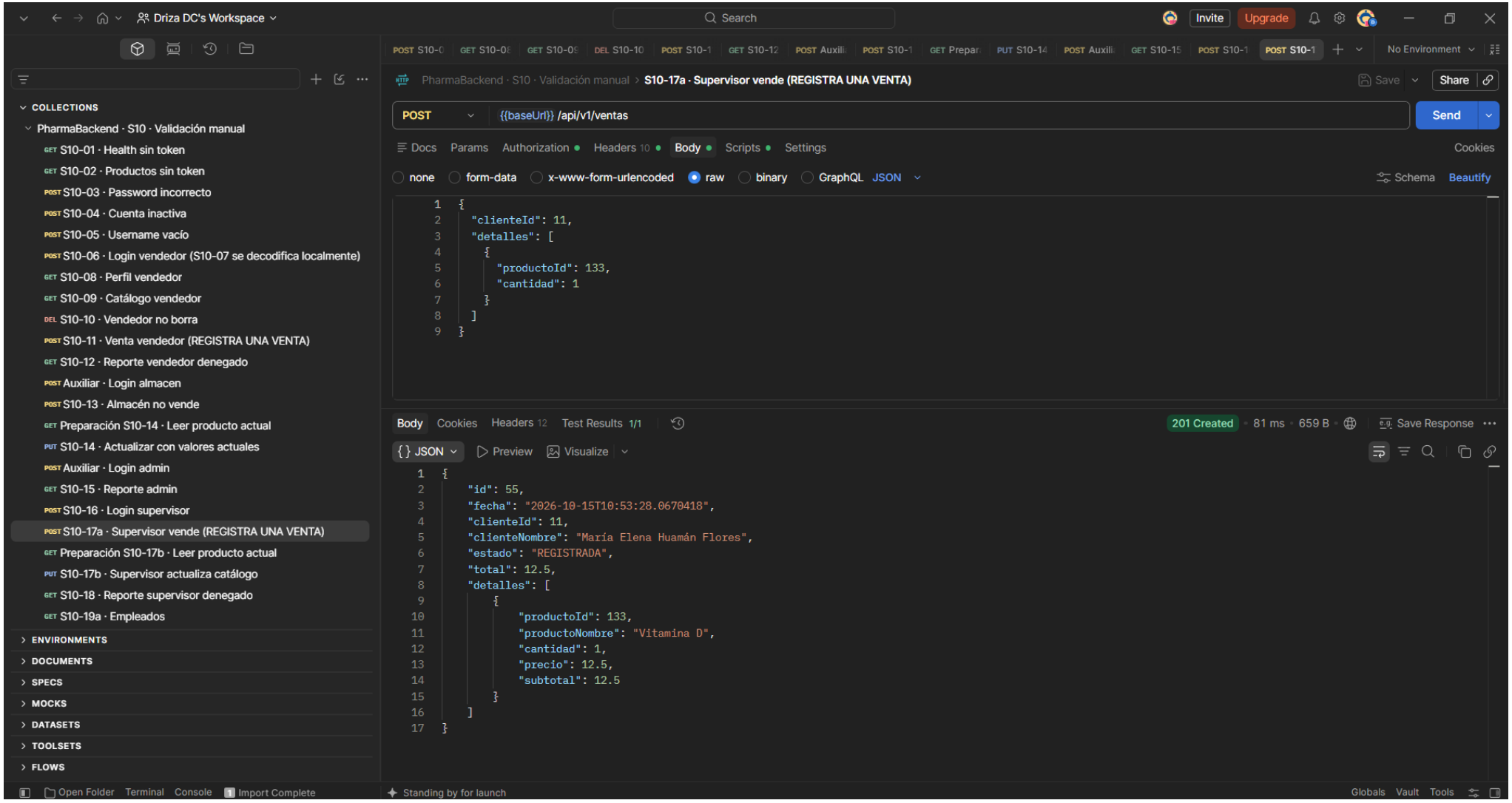
S10-16 · Login de supervisor

Respuesta 200 con roles ALMACENERO y VENDEDOR, y la unión de sus permisos.



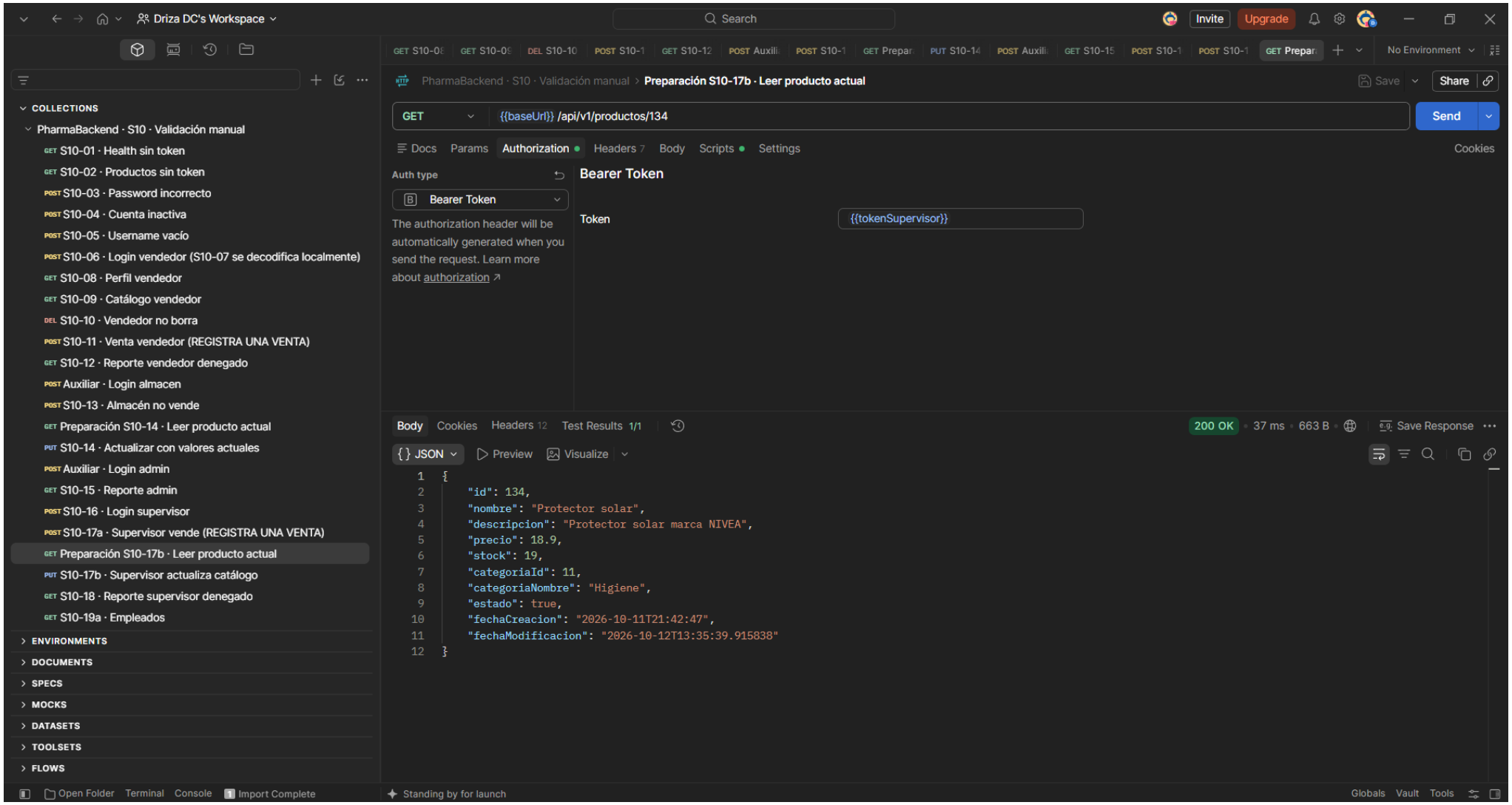
S10-17 · Supervisor registra una venta

POST ventas crea la venta 55 por S/12.50: cliente 11, producto 133 y cantidad 1; HTTP 201.



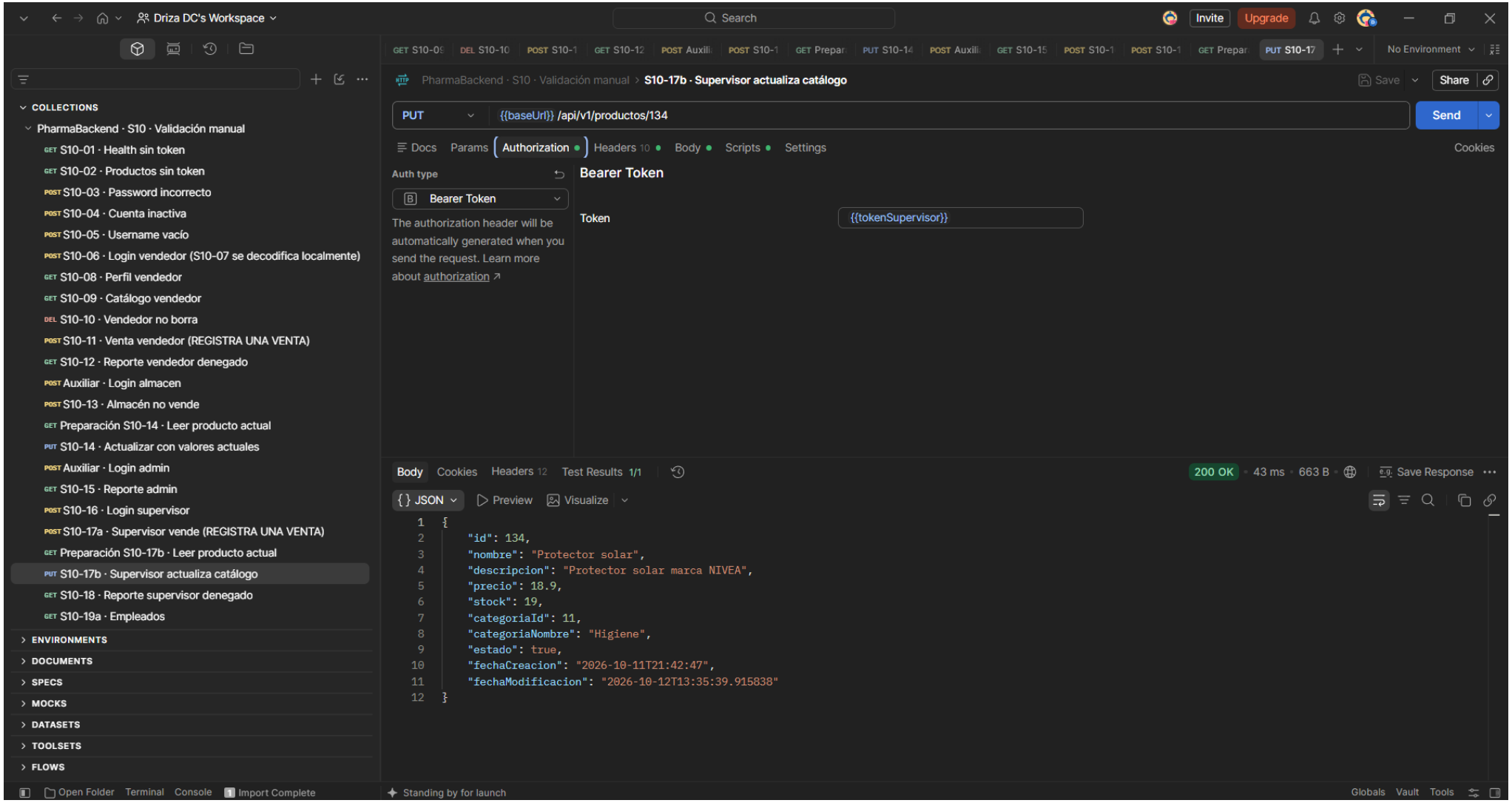
S10-17 · Supervisor consulta el producto

GET productos/134 con tokenSupervisor: 200 y valores actuales del producto.



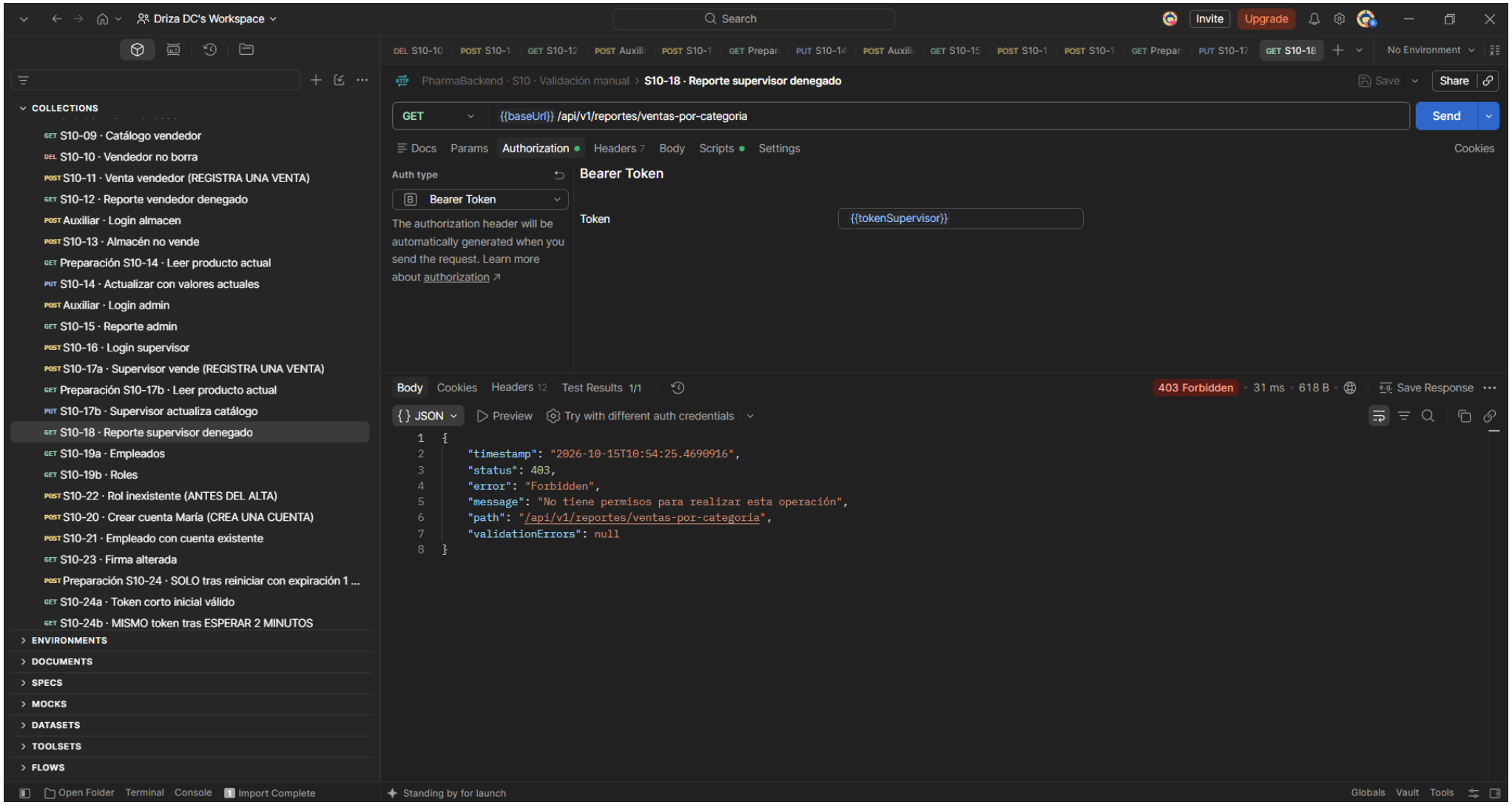
S10-17 · Supervisor actualiza catálogo

PUT productos/134 con tokenSupervisor: 200, además del permiso de venta demostrado en el mismo caso.



S10-18 · Reporte denegado al supervisor

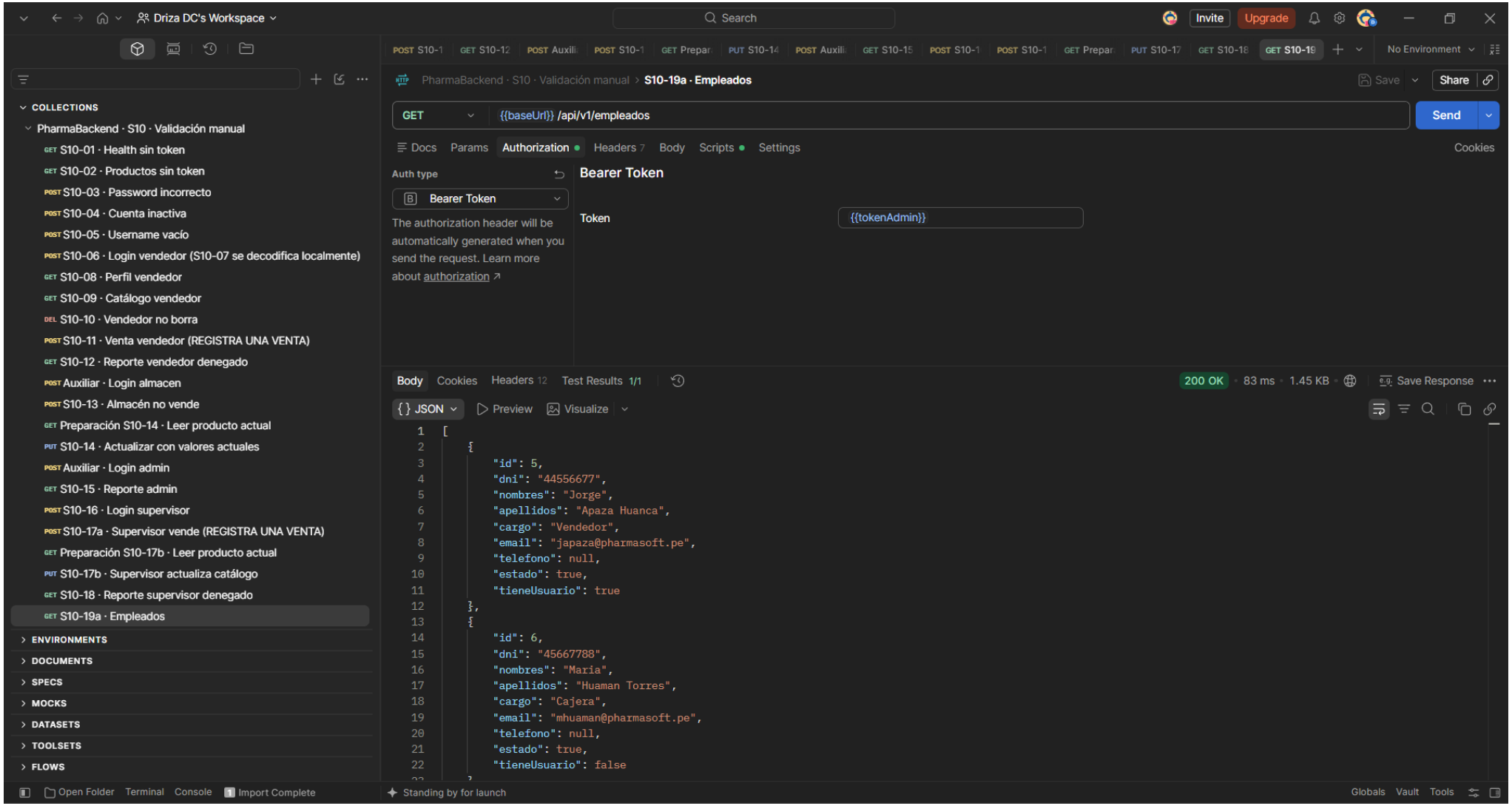
TokenSupervisor recibe 403: la combinación de sus dos roles no concede REPORTES_VER.



Usuarios y relaciones

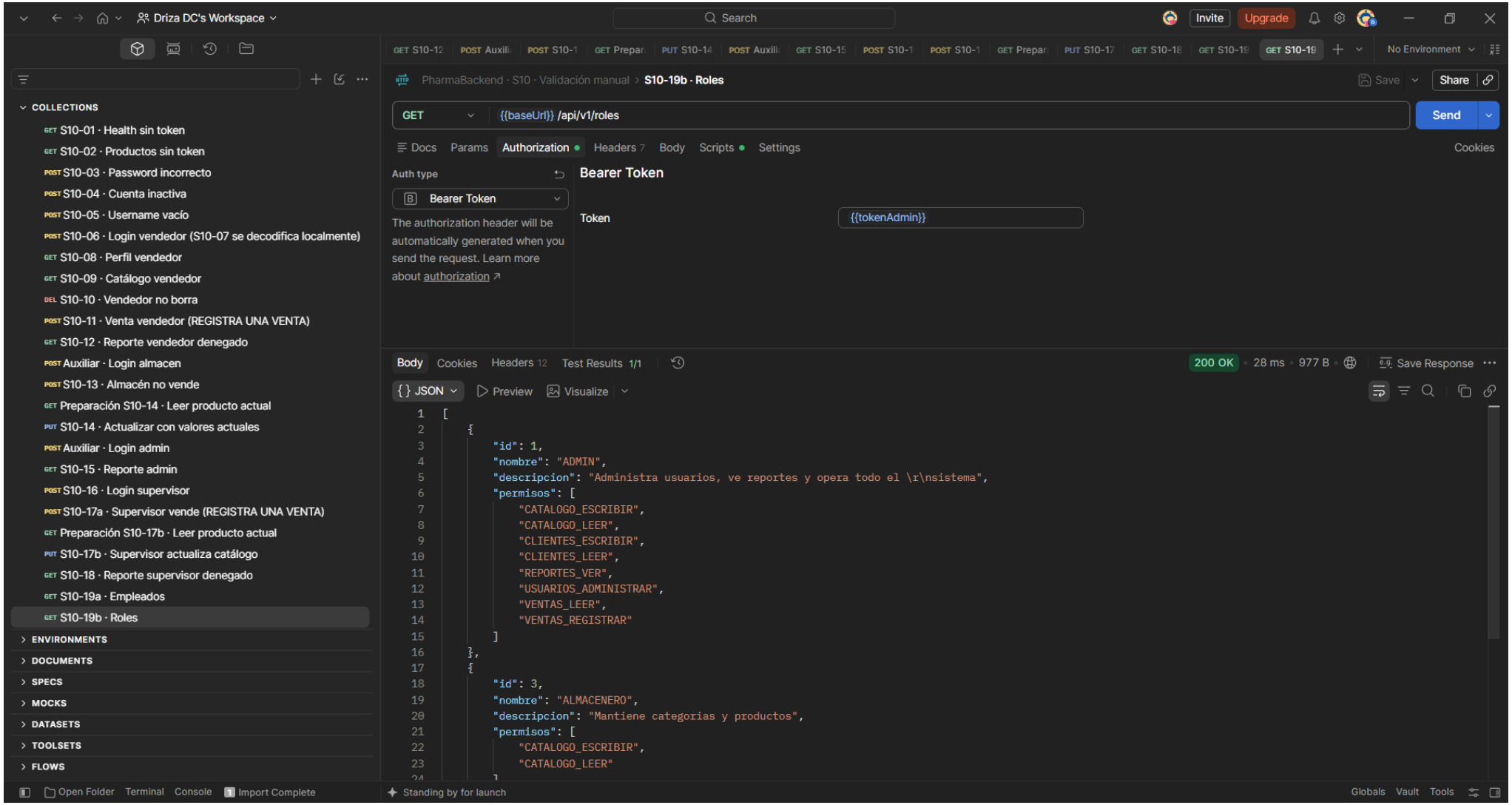
S10-19 · Empleados y disponibilidad de cuenta

GET empleados con tokenAdmin responde 200; María Huamán, empleado 6, aparece sin usuario.



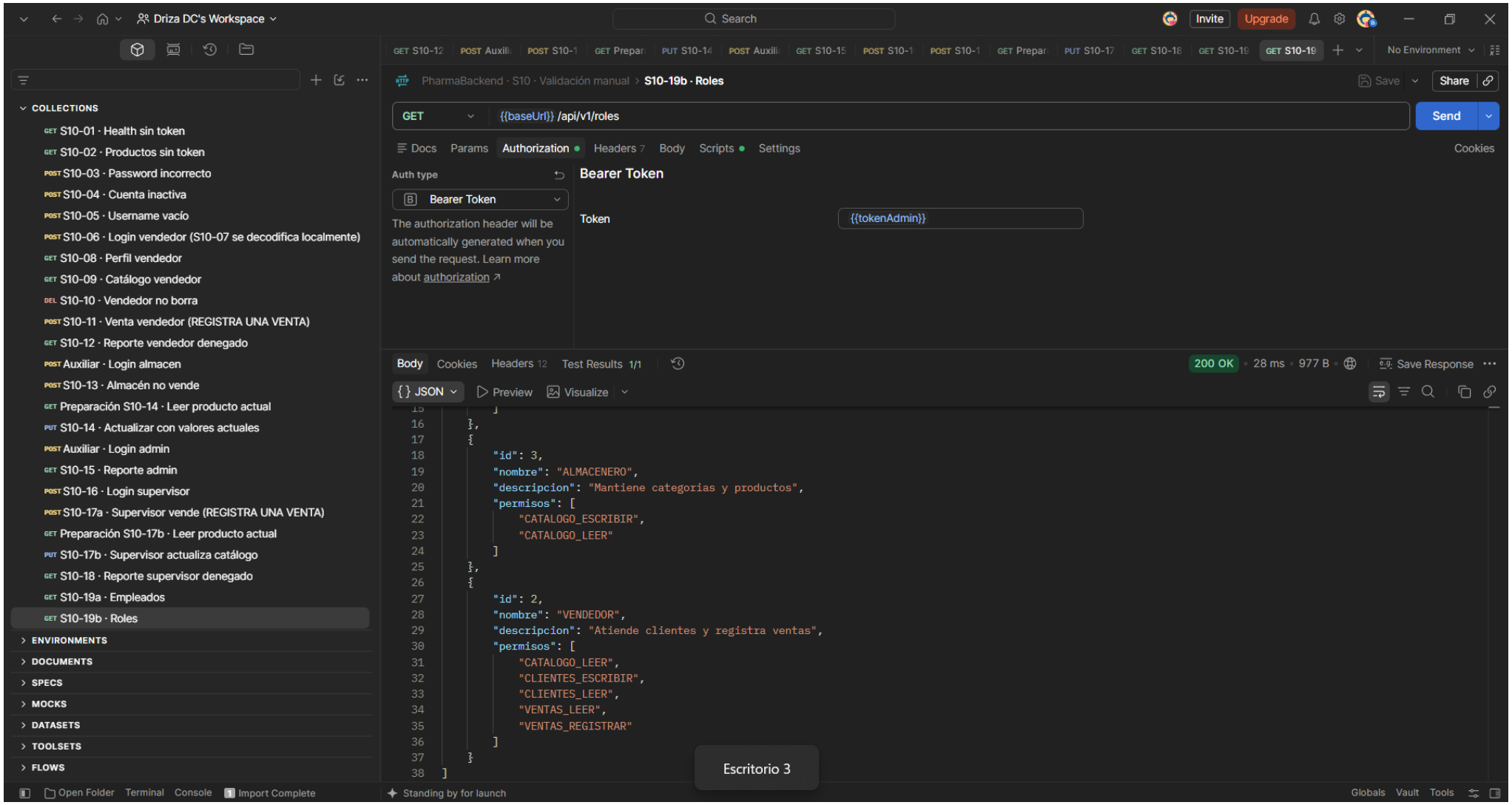
S10-19 · Roles y permisos administrativos

GET roles devuelve 200 e incluye ADMIN y ALMACENERO con sus permisos.



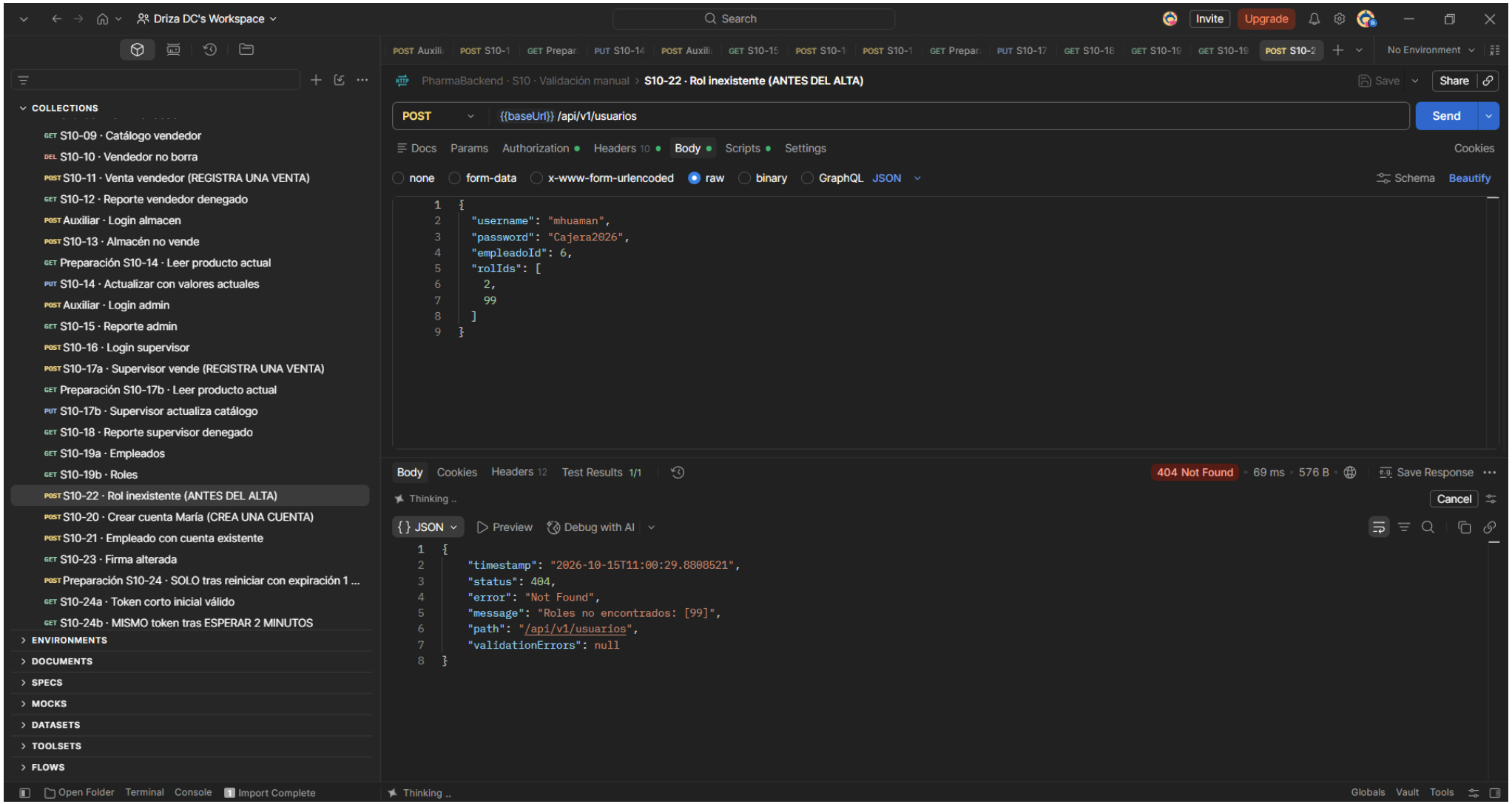
S10-19 · Rol VENDEDOR disponible

Continuación de la respuesta de roles: VENDEDOR, id 2, con sus permisos de clientes y ventas.



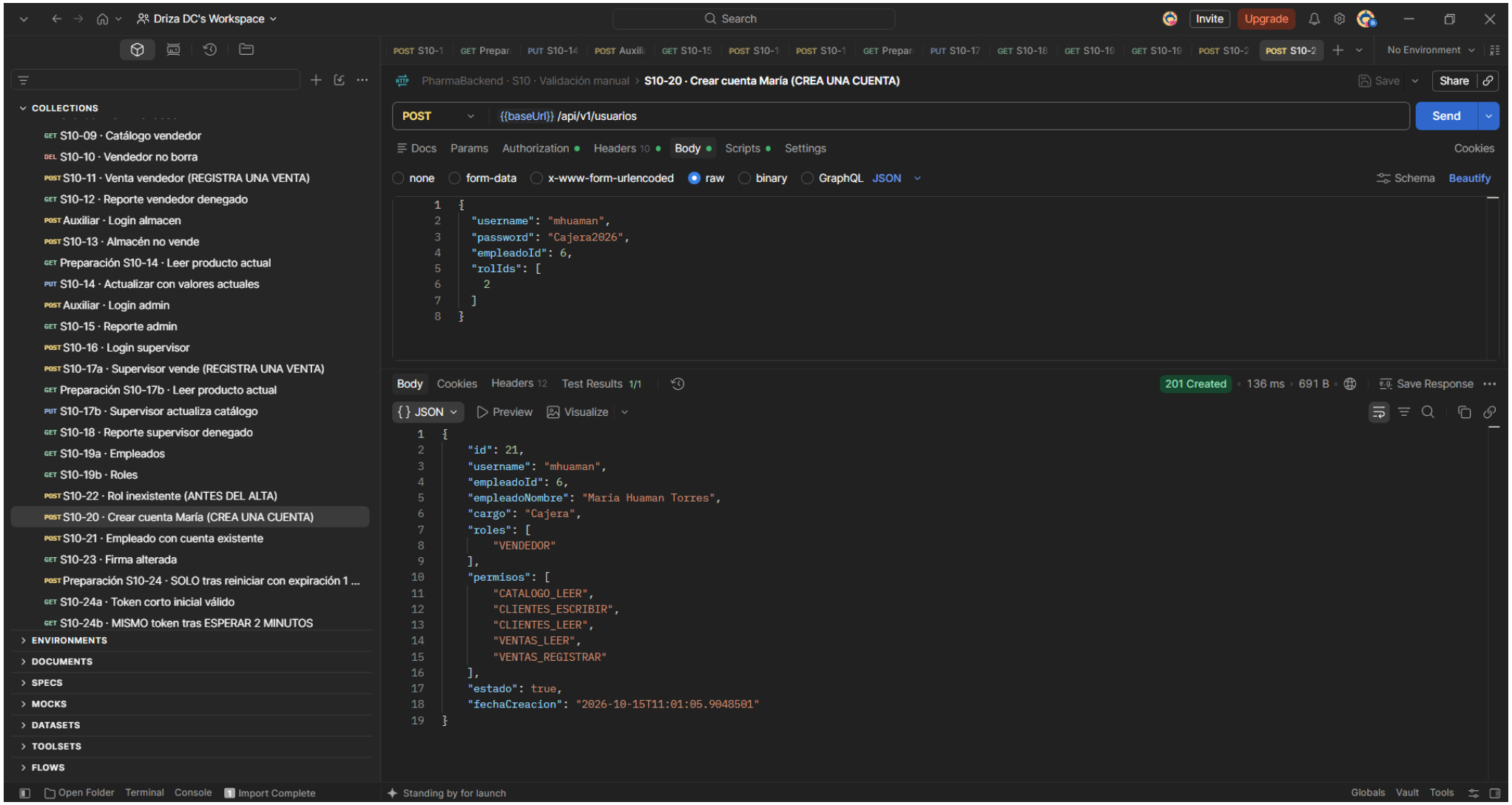
S10-22 · Rechazo de rol inexistente

Alta con rolIds 2 y 99 recibe 404: Roles no encontrados: [99]. Se ejecuta antes del alta válida.



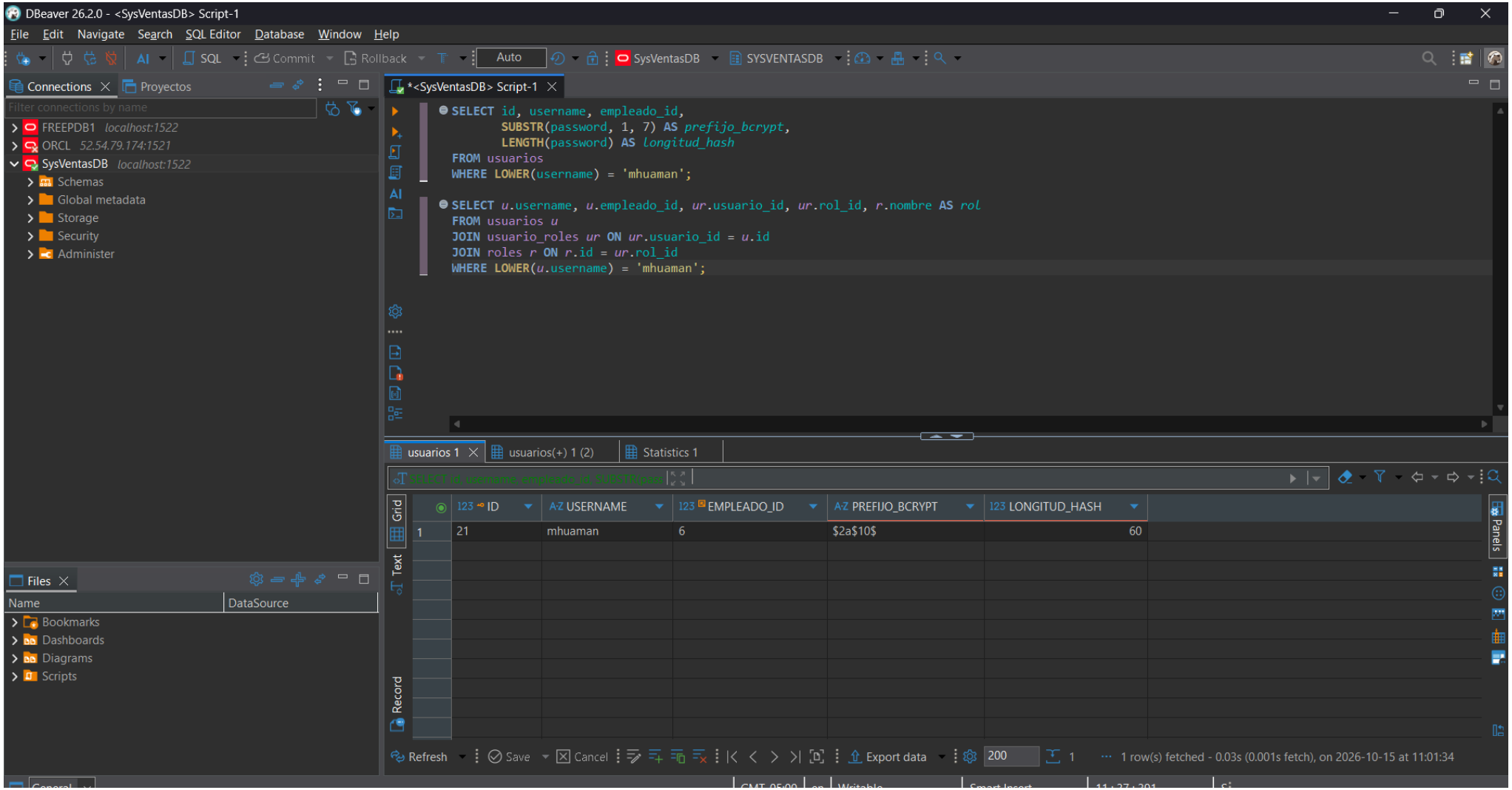
S10-20 · Creación de la cuenta mhuaman

POST usuarios devuelve 201: usuario 21, empleado 6, rol VENDEDOR y permisos, sin contraseña en la respuesta.



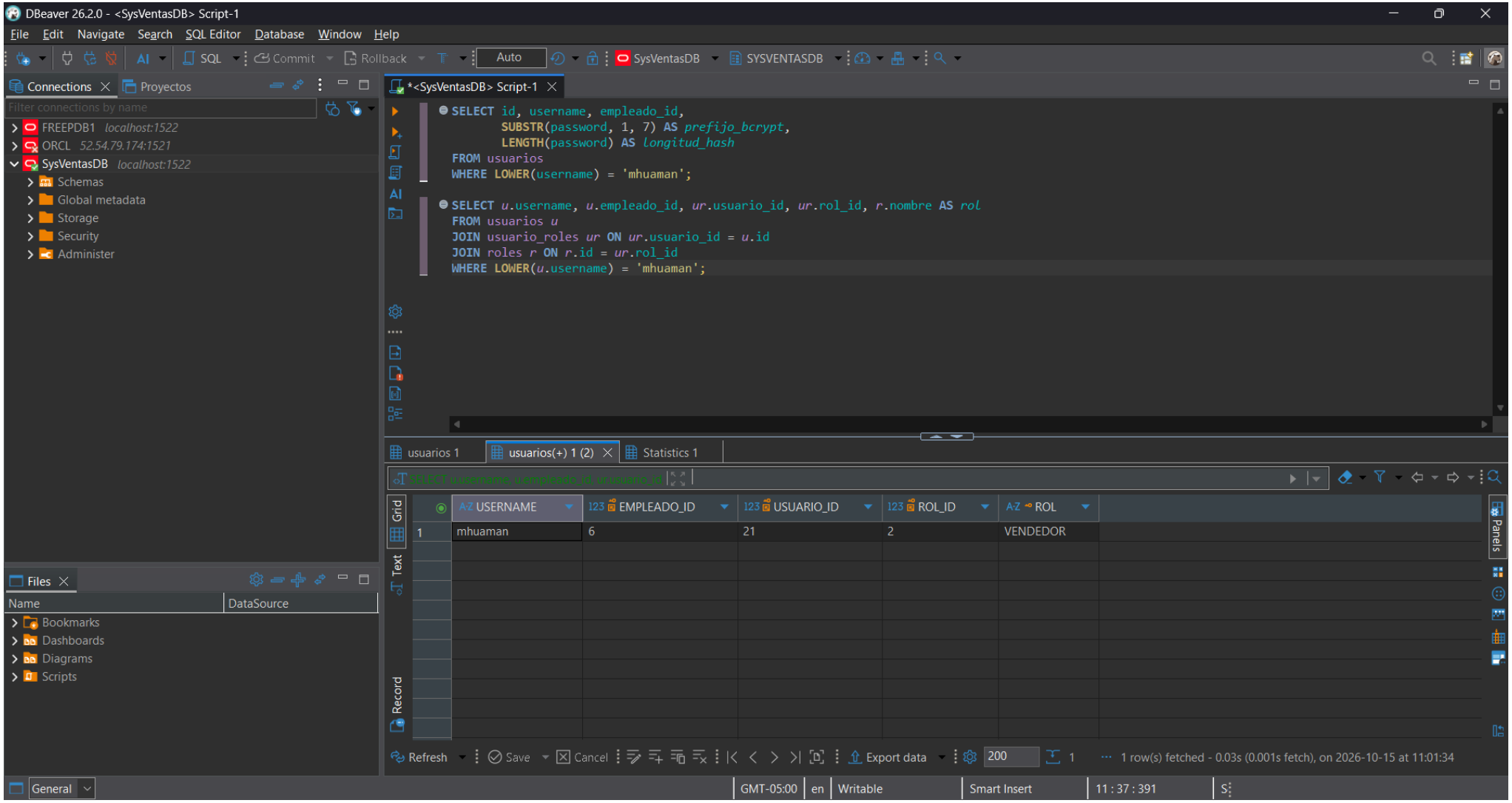
S10-20 · Hash BCrypt persistido

Consulta Oracle de mhuaman: prefijo $2a$10$, longitud de hash 60 y empleado_id 6.



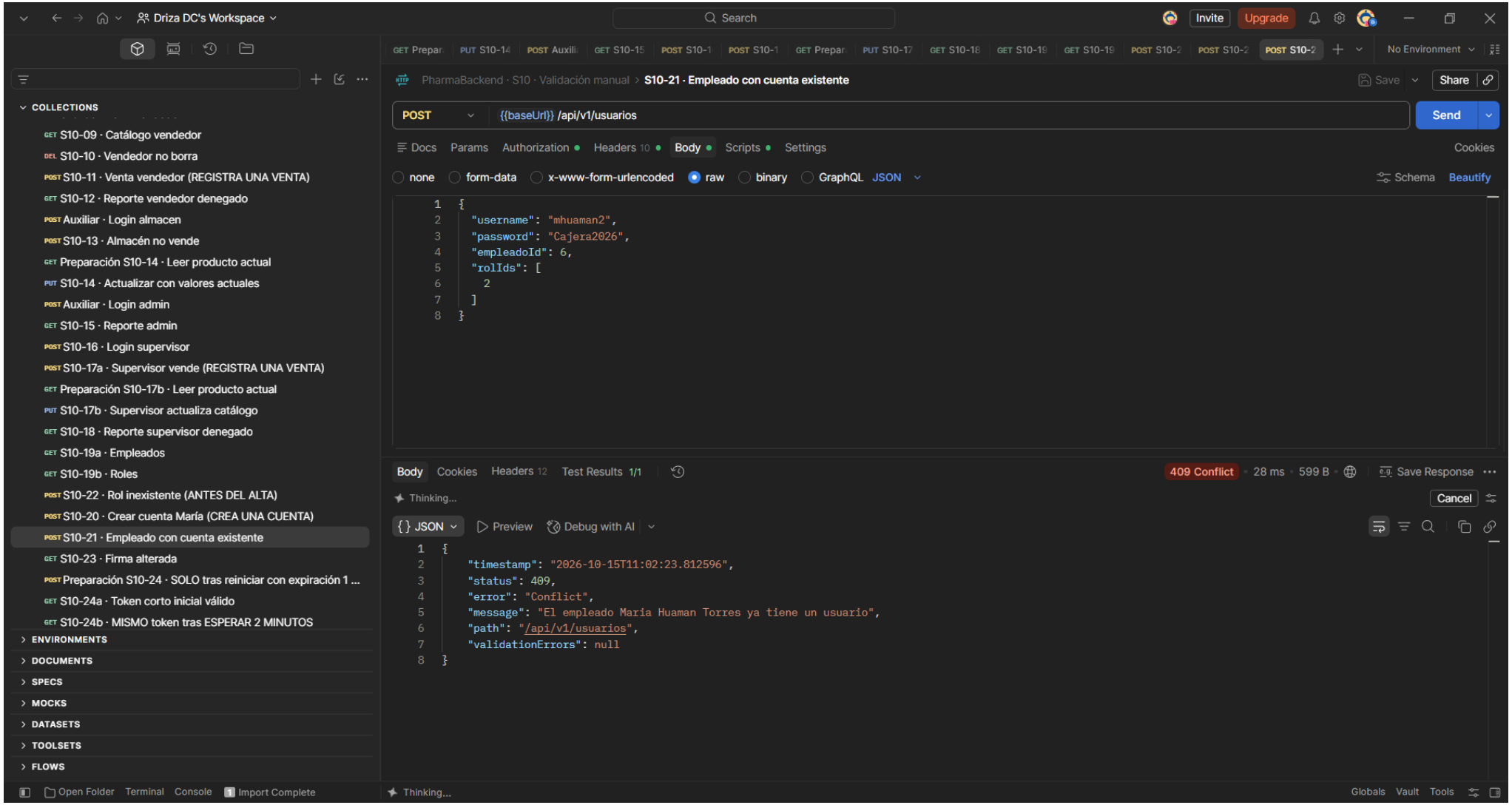
S10-20 · Relación de usuario y rol

Consulta Oracle une mhuaman, empleado 6 y rol 2 VENDEDOR mediante usuario_roles.



S10-21 · Un empleado, una cuenta

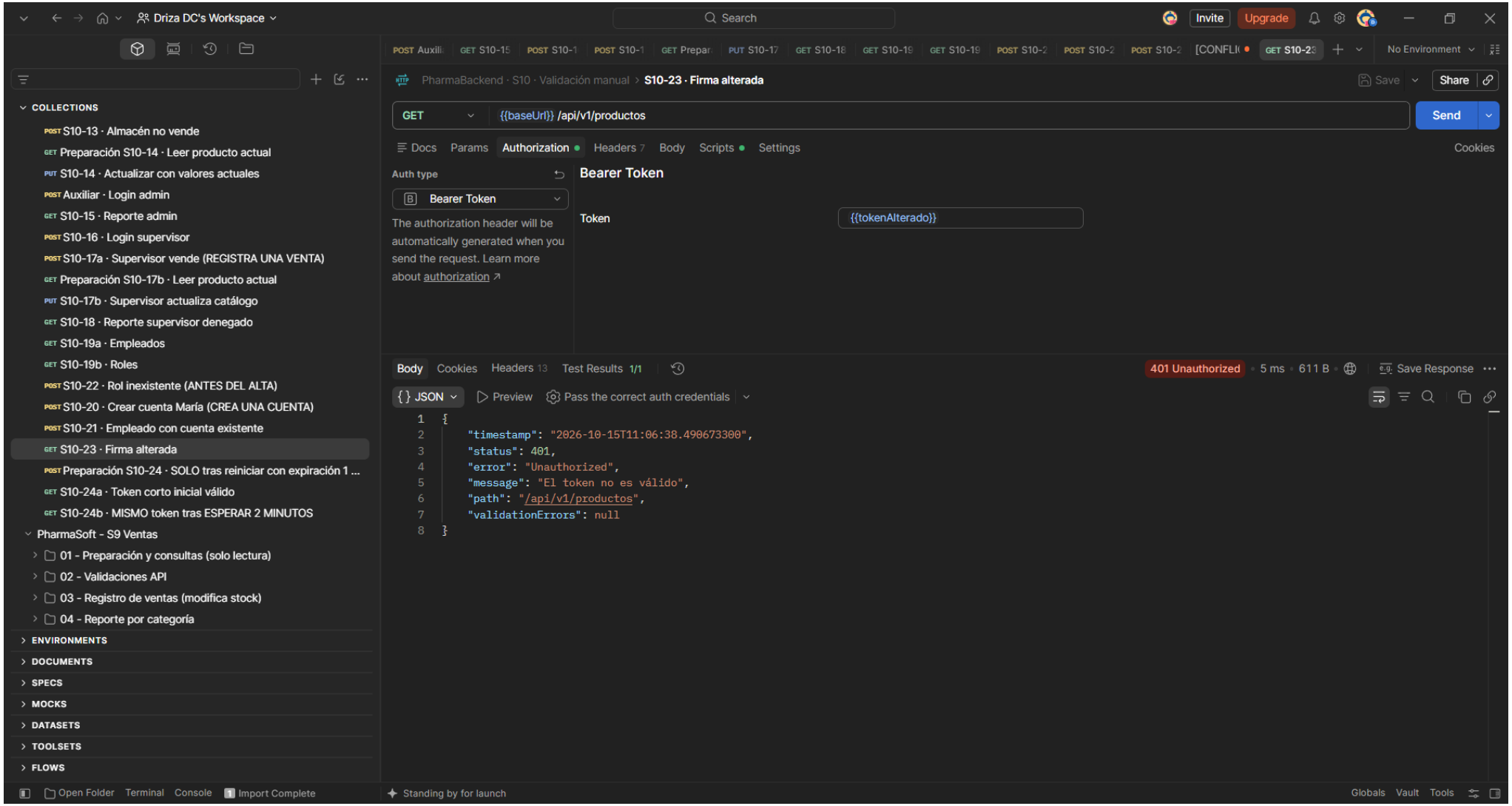
Intento de mhuaman2 para empleado 6 recibe 409: El empleado Maria Huaman Torres ya tiene un usuario.



Integridad y expiración del token

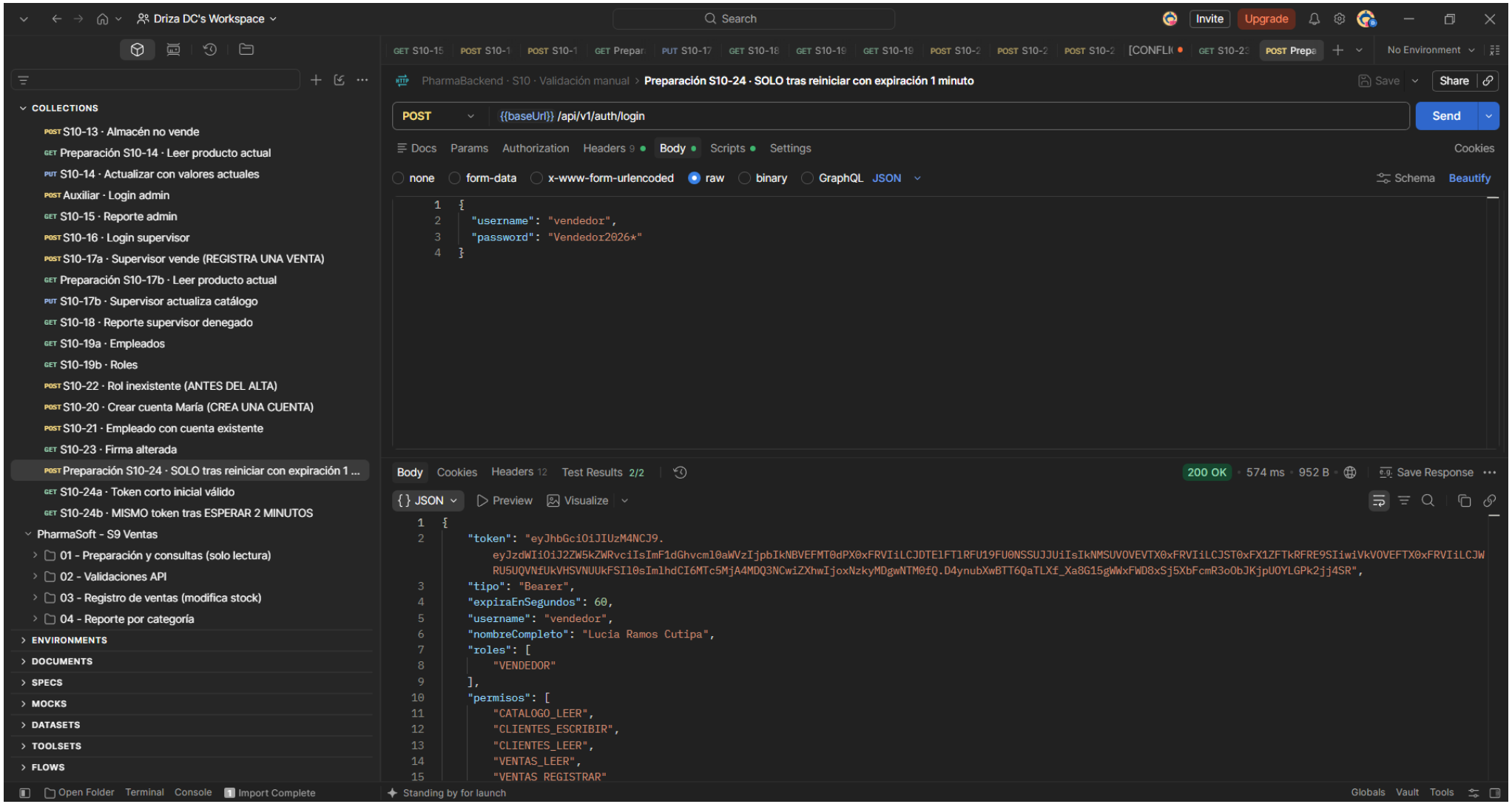
S10-23 · Firma de token alterada

GET productos con tokenAlterado responde 401: El token no es válido.



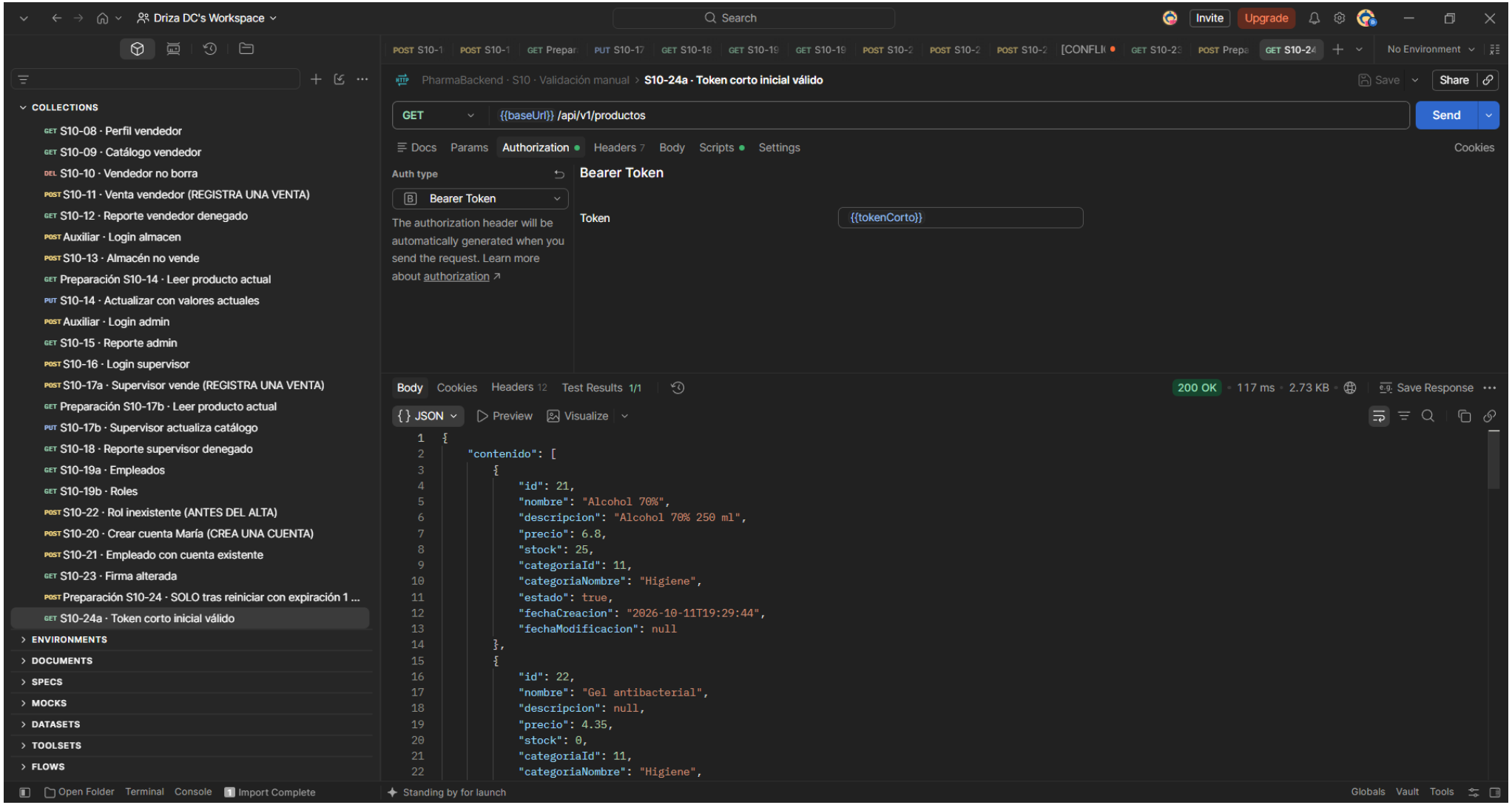
S10-24 · Primera emisión de token corto

Login vendedor con duración configurada de 60 segundos y respuesta 200.



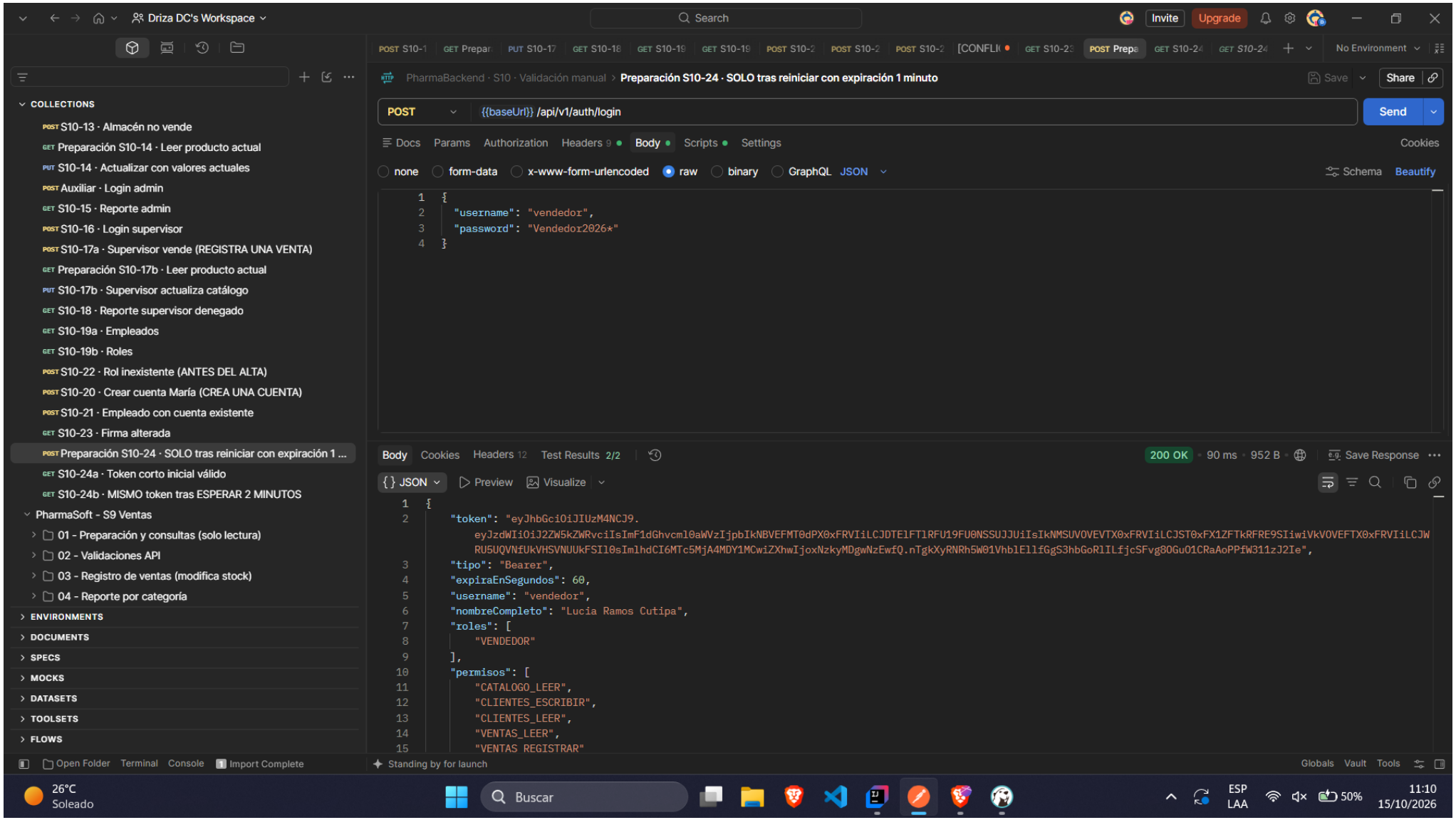
S10-24 · Acceso con token corto

GET productos con tokenCorto obtiene 200 en la comprobación inicial.



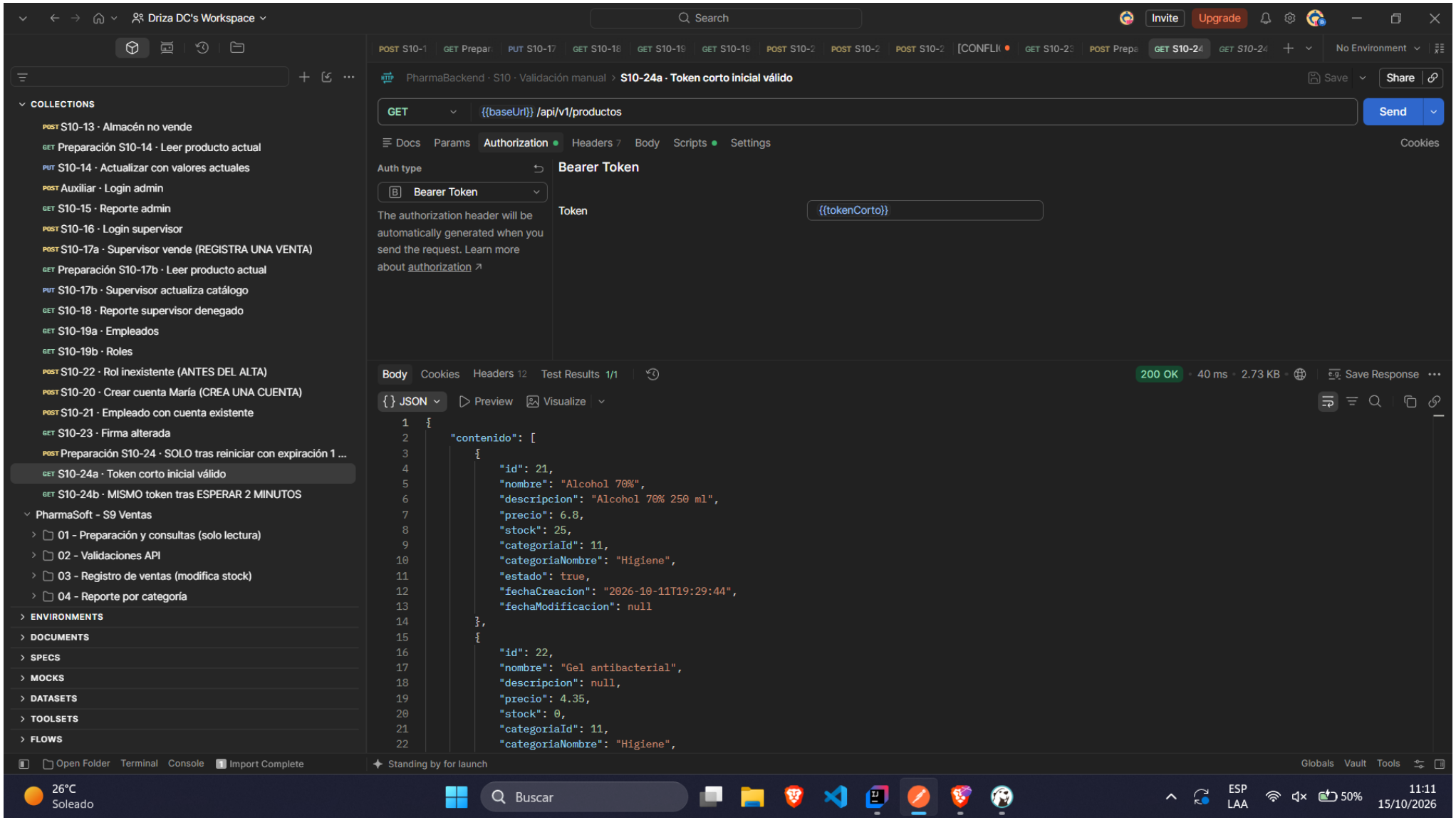
S10-24 · Nueva emisión de token de un minuto

Segunda secuencia de emisión: login vendedor 200 y expiraEnSegundos 60.



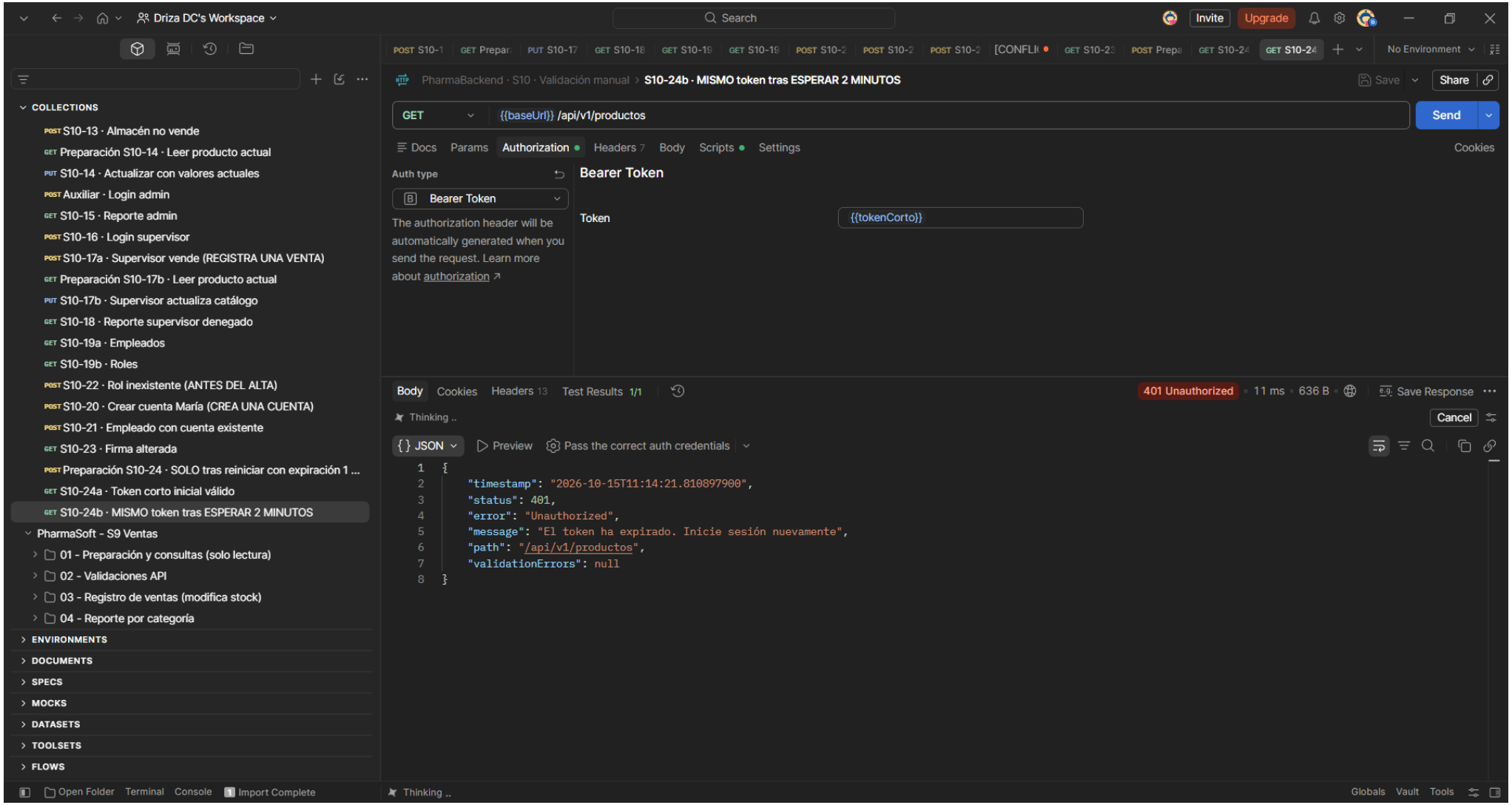
S10-24 · Acceso válido de la segunda secuencia

El GET con tokenCorto obtiene 200 después de la nueva emisión.



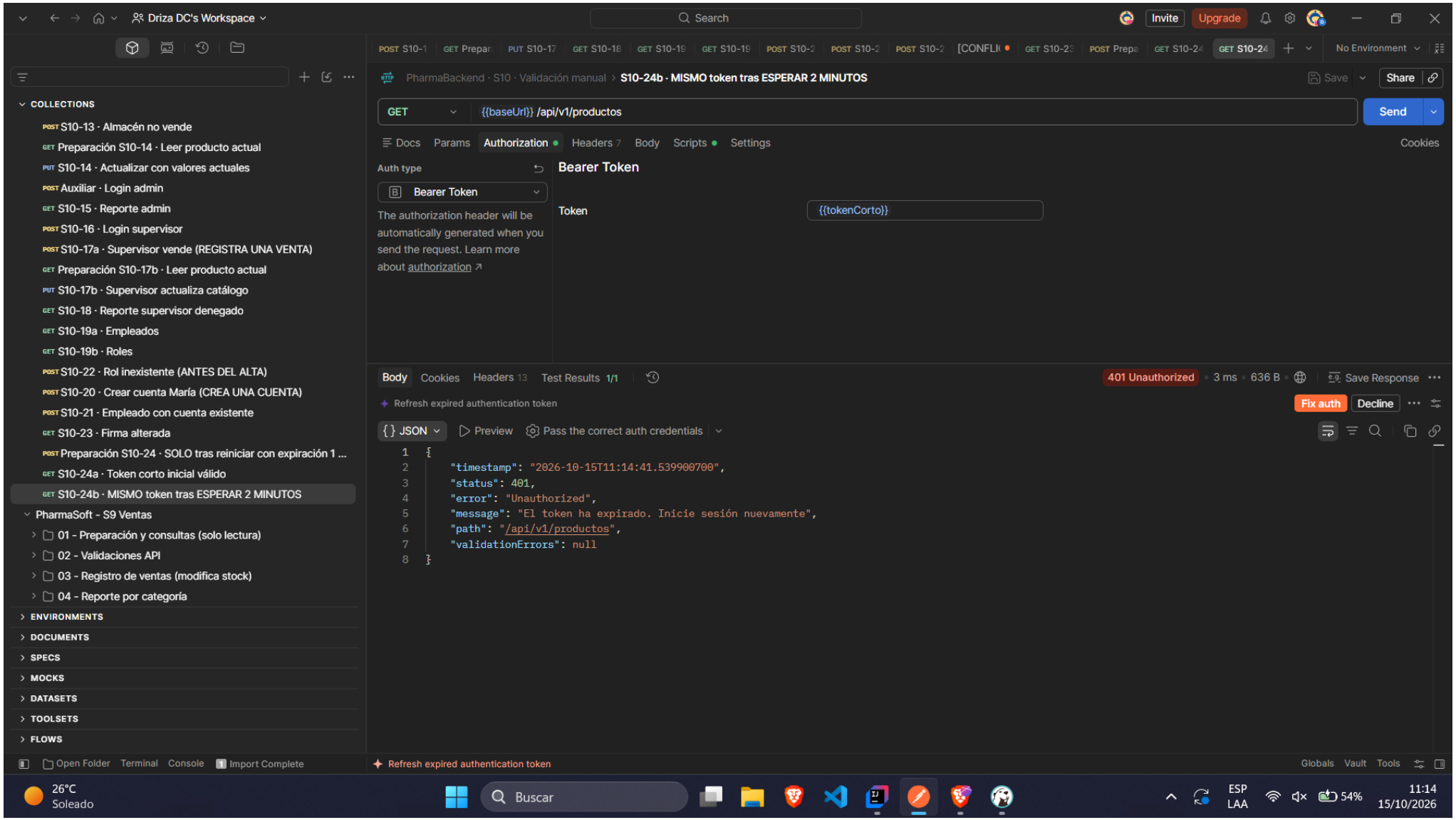
S10-24 · Rechazo tras la expiración

El mismo tipo de petición con tokenCorto devuelve 401: El token ha expirado. Inicie sesión nuevamente.



S10-24 · Expiración: comprobación adicional

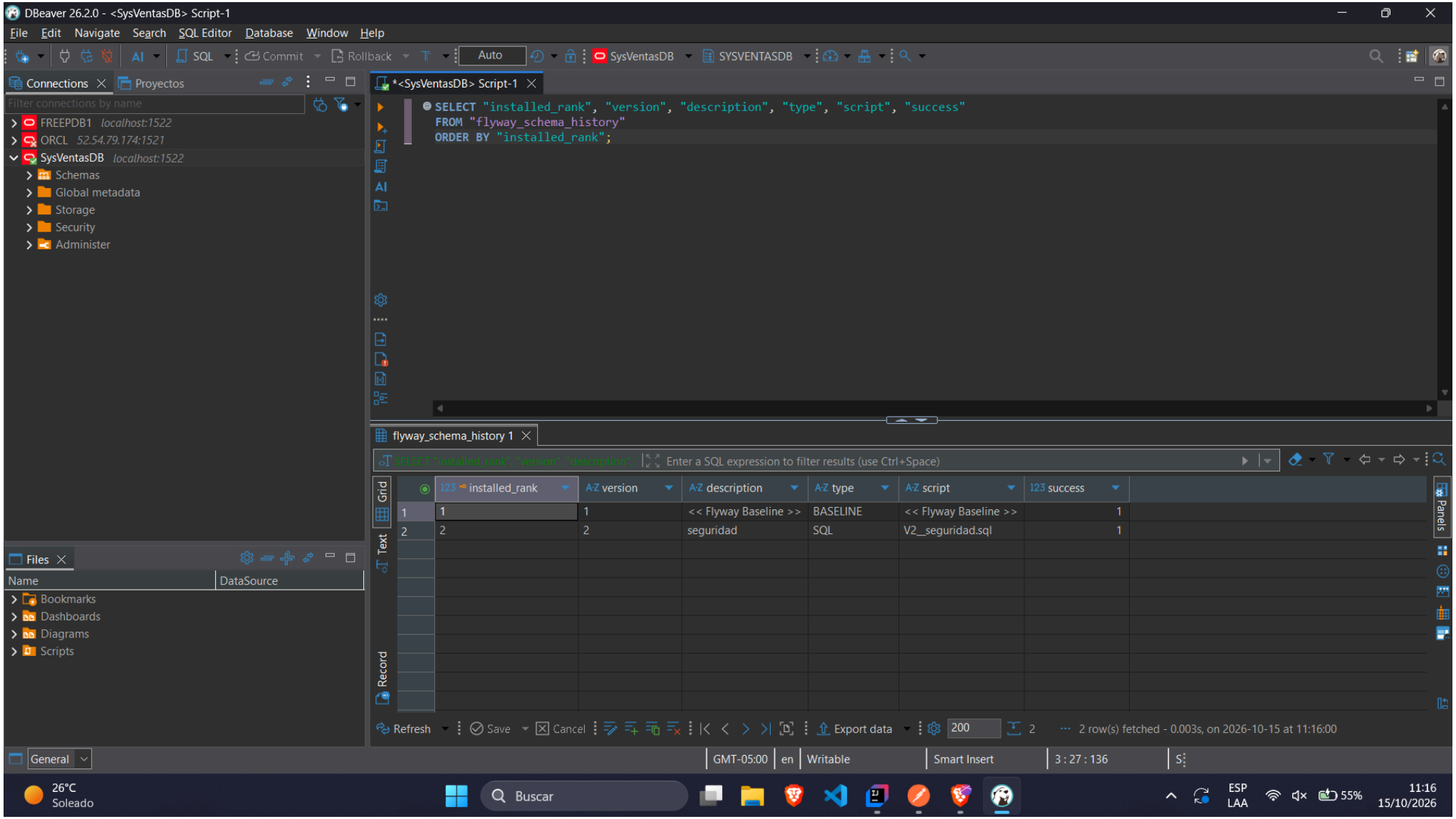
Nueva comprobación del token corto vencido: 401 con el mismo mensaje de expiración.



Persistencia y pruebas unitarias

Historial de migraciones

Oracle muestra baseline de versión 1 y V2 seguridad aplicada como SQL, ambas con success 1.



Pruebas unitarias de seguridad

JwtServiceTest: cinco pruebas; PermisosPorRolTest: cuatro. Nueve ejecutadas, sin fallos, errores ni omisiones; BUILD SUCCESS.

